

Can We Trust Large Language Models Generated Code? A Framework for In-Context Learning, Security Patterns, and Code Evaluations Across Diverse LLMs

Ahmad Mohsin^a, Helge Janicke^a, Adrian Wood^a, Iqbal H. Sarker^a, Leandros Maglaras^b and Naeem Janjua^b

^aCentre for Securing Digital Futures, School of Science, Edith Cowan University, WA-6027, Australia

^bSchool of Computing, Edinburgh Napier University, United Kingdom

^cCollege of Science and Engineering, Flinders University, Adelaide, Australia

ARTICLE INFO

Keywords:

Large Language Models, Automated Code Generation, AI and Code Security, Security Vulnerabilities, Hidden Code Smells, In-Context Learning, Supply Chain Vulnerabilities

ABSTRACT

Large Language Models (LLMs) such as ChatGPT and GitHub Copilot have revolutionized automated code generation in software engineering. However, as these models are increasingly utilized for software development, concerns have arisen regarding the security and quality of the generated code. These concerns stem from LLMs being primarily trained on publicly available code repositories and internet-based textual data, which may contain insecure code. This presents a significant risk of perpetuating vulnerabilities in the generated code, creating potential attack vectors for exploitation by malicious actors. Our research aims to tackle these issues by introducing a framework for secure behavioral learning of LLMs through In-Context Learning (ICL) patterns during the code generation process, followed by rigorous security evaluations. To achieve this, we have selected four diverse LLMs for experimentation. We have evaluated these coding LLMs across three programming languages and identified security vulnerabilities and code smells. The code is generated through ICL with curated problem sets and undergoes rigorous security testing to evaluate the overall quality and trustworthiness of the generated code. Our research indicates that ICL-driven one-shot and few-shot learning patterns can enhance code security, reducing vulnerabilities in various programming scenarios. Developers and researchers should know that LLMs have a limited understanding of security principles. This may lead to security breaches when the generated code is deployed in production systems. Our research highlights LLMs are a potential source of new vulnerabilities to the software supply chain. It is important to consider this when using LLMs for code generation. This research article offers insights into improving LLM security and encourages proactive use of LLMs for code generation to ensure software system safety.

1. Introduction

The transformation of LLMs has revolutionized software development from agile DevOps to cloud infrastructure automation. However, the quality of generated code is a critical issue, with code security being the primary concern. Tools like GitHub Copilot and ChatGPT have improved developers productivity by automating various tasks [1, 2, 3] for code generation. The, software-intensive systems employing generated code through LLMs are posed with significant security risks, primarily due to the generated source code containing various security weaknesses and hidden bugs. As they are trained on extensive data from human developers extracted from open source repositories,

these LLMs often produce code with security vulnerabilities. This results in potential security threats due to vulnerabilities [4] present in the produced code.

These models lack an understanding of security principles; their primary goal is to produce operational code without considering security flaws during code generation [5]. Studies have indicated that different versions of ChatGPT and GitHub Copilot generated insecure code in approximately 40% of cases reported, highlighting significant security risks [4, 6, 7]. Researchers and industry practitioners have expressed concerns about the reliability of source code generated by LLMs for software security [6, 8]. These models generate probabilistic code using sequential learning by transforming natural language inputs into token sequences and embeddings [8, 9, 10, 11]. The LLM model is trained mainly on internet-based datasets, which makes the output code susceptible to various security issues. To understand this process better, let us consider the LLM code generation process illustrated in Figure 1. For instance, if we have input text such as "Write a Python function to calculate factorial", the LLM model tokenizes the input, applies learned embeddings using training datasets, and its transformer

*This research work is supported by the School of Science Center for Securing Digital Futures (CSDF) and Cyber Security Co-operative Research Centre (CSCRC) Australia, under the Research Theme for AI and Cybersecurity.

*Corresponding author (First author) at School of Science, Computing and Security Discipline Joondalup, Australia

✉ a.mohsin@ecu.edu.au (A. Mohsin); h.janicke@ecu.edu.au (H. Janicke); adrian.wood@ecu.edu.au (A. Wood); m.sarker@ecu.edu.au (I.H. Sarker); l.maglaras@napier.ac.uk (L. Maglaras); naeem.janjua@flinders.edu.au (N. Janjua)

ORCID(s):

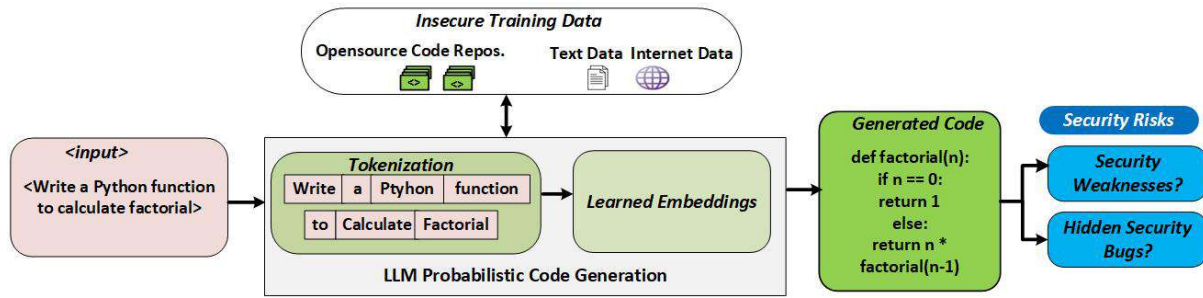


Figure 1: The LLM code generation process: simplified Transformer architecture for code generation with potential security risks

architecture to output a sequence of tokens that forms the appropriate Python code. However, the overall security of the generated source code is a significant question mark and challenge for software developers and LLM users. When deployed in production systems, this poses a significant security risk, potentially compromising trustworthiness and resilience [12]. It is crucial to thoroughly test the generated code before deployment, especially since developers may not fully understand how it is generated [6, 13, 4] and may lack security knowledge.

When interacting with LLMs, developers with varying coding expertise can inadvertently introduce security vulnerabilities, leading to the unintentional generation of less secure or malicious code. Unfortunately, most developers are unaware of the security implications of their inputs to LLMs. The resulting vulnerabilities can be exploited through various attack vectors, compromising the integrity of software systems [14, 15]. Therefore, it is essential to note that developers using LLMs may have limited knowledge about security[16, 4].

Code generating LLMs exhibit different behaviors depending on the language model type and underlying architecture they are trained [17]. The behavior of prompt-driven code generators using Foundation or Baseline LLMs such as GPTs [18, 10] is different from that of fine-tuned LLMs [19, 20, 21] used in coding copilots. Existing research efforts [22, 23] do not address these aspects when evaluating AI platforms for coding. The current research is currently focused solely on standalone LLMs functional code evaluations [8], with little emphasis on code generation using diverse LLM types, especially with regard to security. Existing research only concentrates on the security of generated code and identifying specific vulnerabilities [22, 24], while some through instruction fine-tuning, which is expensive and unreliable [1, 5]. However, there is a lack of experimental research that trains LLMs to acquire security knowledge during code generation. This is crucial for providing a comprehensive and empirical analysis of code security and the associated risks. These research gaps could lead to severe cybersecurity risks if not appropriately addressed.

We have developed an approach named "Can We Trust Large Language Models Generated Code? A Framework for In-Context Learning, Security Patterns, and Code Evaluations Across Diverse LLMs" to address these challenges. We argue LLMs are effective few-shot learners that use a gradual in-context learning approach, aided by natural language inputs [25, 17, 26]. This framework enables various LLMs to acquire security knowledge and understand security by implementing ICL security patterns, followed by extensive security testing to assess their ability to produce safe and secure code. Four different LLM platforms are used with three programming languages: C++, C#, and Python. The code experimentation employing ICL patterns against LLMs involves a diverse set of problem sets, ranging from classic data structures and algorithms to modern web and API development. We conduct experiments for code generation using prompt-driven code generators (PDCGs) such as ChatGPT and Google Bard, along with Coding CoPilots (CCPs) like GitHub Copilot and Amazon Code Whisperer. Rigorous testing and analysis of the generated code is carried out across various programming scenarios to evaluate security risks. ICL security patterns are utilized to generate code for instructing and fine-tuning coding LLMs, leading to the creation of two distinct datasets for future LLM security research.

We apply each ICL security pattern specifically within programming language problem-solving scenarios to ensure they are repeatable and applicable across the four LLMs. This approach aims to improve LLMs learning behaviors through tailored ICL patterns for both pre-trained (Foundation or Base models) and fine-tuned models. We rigorously test the security of each generated program instance using Static Application Security Testing (SAST), complemented by manual security reviews of selected programs to identify and analyze security vulnerabilities and hidden code smells, respectively. Focusing on risk management, we developed security risk metrics to quantify security impacts at the source code level.

Our main contributions in this research work are as follows:

- Our novel approach offers LLMs an opportunity to learn about security knowledge using ICL security patterns which are designed to enhance their ability to produce secure code.
- We curate diverse programming problem sets in widely used programming languages in C++, C#, and Python to generate extensive code bases using ICL security patterns.
- We use four diverse LLMs to improve their security learning behavior using ICL and analyze their code secure generation capabilities. Each LLM is fed with tailored instruction sets considering its contextual and dynamic interactions during the code generation process.
- We perform security assessments on the generated LLM code using industry-standard Static SAST and code reviews to evaluate potential vulnerabilities and hidden code issues. Our developed security risk assessment metrics help to identify threats to the overall quality of the generated LLM code.
- We aim to release a security instructions dataset used to design ICL patterns. This dataset can later be utilized to train and fine-tune LLMs for secure code generation. The generated code is a curated dataset intended for future LLM security training for experimental purposes.

Concepts and terms used in this study, along with research questions, are described in Section 2. We delve into related work for AI-based code generation and research on evaluating LLMs for code generation in Section 3. Section 4 presents the proposed research approach for this study. Experimentation and results analysis are detailed in Sections 5 and 6, respectively. Discussion on the results is provided in Section 7, followed by Conclusions and Future Research in Section 8.

2. Background & Research Problematic

This section covers key concepts in this article: AI for code generation, code-generating LLM types, learning behaviors, and source code security vulnerabilities. It defines essential concepts and terms for a better understanding of the terminology used in the following discussion. It covers the evolution of LLM code generation, its two main types, related software security terms, methods for training LLMs to learn code behavior, and ways to ensure code quality.

2.1. Code Generation Evolution with LLMs

With LLM advancements, several AI-based code generators have emerged to help developers improve their productivity across various platforms. Some notable examples of these platforms are Google Bard,

AmazonCode Whisperer [20], Hugging Face StarCoder [19], and Facebook Code Llama [27]. These platforms use Transformer Architecture [28] for code generation, functioning as conversational code generators allowing developers to input prompts and receive code outputs. They also integrate plugins within IDEs, acting as programming assistants or pair programmers. This advancement in LLM technology lays the foundation for understanding the unique functionalities and applications of Prompt Driven Code Generators (PDCGs) and Coding CoPilots (CCPs), tailored to different aspects of coding assistance and developer interaction.[29, 30, 21, 31, 13, 32, 33]. We describe these as follows:

(i) Prompt Driven Code Generators (PDCGs). The PDCGs are platforms such as OpenAI ChatGPT that utilize foundation models, or Baseline LLMs (BLLMs¹), trained on various datasets. These models generate code in response to specific prompts and inputs/queries that developers provide. For example, a developer might input a query "computing the prime values of the first 999 numbers in an array," the LLM interprets this input using NLP to generate the corresponding code. These interactions heavily rely on the capabilities of the BLLMs [29, 30, 21, 31]. Please refer to Figure 2 to illustrate PDCG usage. PDCGs that use foundation models have certain limitations and constraints, especially when dealing with complex problems specific to programming languages that require task-specific or domain-specific features from pre-trained LLMs.

(ii) Coding CoPilots (CCPs). The CCPs, such as Microsoft GitHub Copilot, are based on FLLMs². These finely-tuned language models are trained with coding-specific datasets to provide context-driven automated code-generation capabilities for developers. These models seamlessly integrate into Integrated Development Environments (IDEs) as plugins or APIs, providing context-sensitive and sophisticated coding assistance. They enhance code completion capabilities by interpreting the context of the project and the developers' intent from specific comments or code snippets. This refined tuning allows CCPs to offer highly pertinent code suggestions and enhancements, effectively adapting to the unique requirements of the development environment and project specifics [13, 32, 33]. Figure 3 illustrates this type of interactive code generation where developers collaborate closely with the LLM.

Both PDCGs and CCPs, as LLMs, are prone to producing insecure code. Being probabilistic code generators, they often introduce security risks due to their tendency vulnerabilities. Below, we describe the vulnerabilities in the generated source code and the related security attacks.

¹Baseline Large Language Models (BLLMs) are foundational models. In this research article, they are referred to as Prompt Driven Code Generators (PDCGs)

²In this paper, CCPs represent fine-tuned, and we shall use CCP for their representation in this article.

Can We Trust Large Language Models Generated Code?

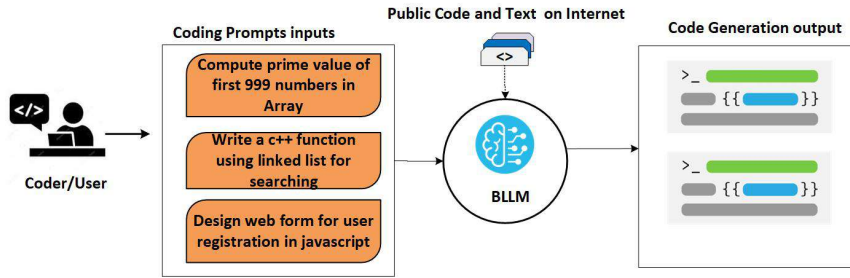


Figure 2: Prompt Driven Code Generators with BLLMs

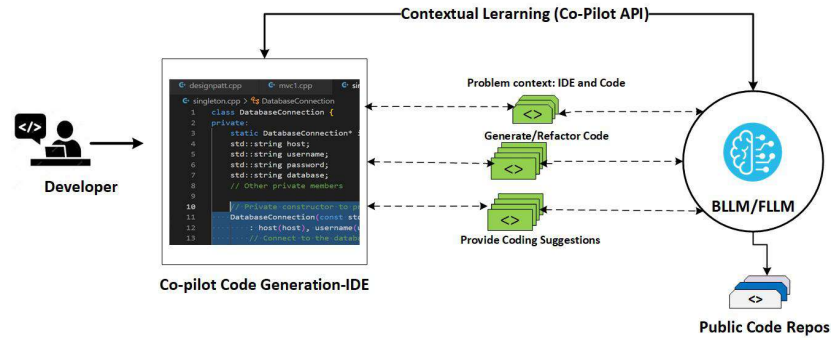


Figure 3: Coding CoPilots LLMs for Code Generation

2.2. Source Code Level Security Defects

Here, we define the nature of software vulnerabilities that may arise from these coding LLMs. This research article will address security-related flaws in generated LLM code as follows:

Source Code Vulnerabilities. A software vulnerability is a source code or system configuration flaw that malicious actors can exploit to compromise data integrity, availability, and confidentiality in computer systems and networks [14]. Software vulnerabilities often result from programming errors, language syntax, or architectural design weaknesses at the source code level. The types of coding weaknesses include input validation errors, application injections, cross-site scripting, information leakage, and buffer overflow, which are categorized under the Common Weakness Enumeration (CWE) [34] vulnerabilities. The CWE is a publicly developed database that categorizes software security weaknesses stemming from poor design and coding practices. Vulnerabilities identified in the CWE are recorded in the Common Vulnerabilities and Exposures (CVE) system [35]. This system is a repository of publicly known information about vulnerabilities. Each CVE may correspond to one or more CWEs.

Software Coding Smells. Code smells are subtle, often hidden issues in the software that indicate potential design flaws, potentially complicating future maintenance, bug fixes, or enhancements [36, 37]. During code generation using LLMs, these issues may be concealed and more challenging to identify than explicit vulnerabilities such as CWEs or CVEs, presenting covert risks in the code automatically generated

by language models. We use CWE and code smells to analyze the security of code generated by LLMs. This highlights the importance of addressing these vulnerabilities due to LLMs tendency to produce potentially insecure code. Identifying code smells also helps us evaluate the associated security risks and overall code quality.

Software Supplychain Vulnerabilities. The majority of these vulnerabilities often stem from developers’ code or third-party sources, such as open-source libraries and commercial off-the-shelf (COTS) products used during software design [15, 38]. Software supply chain attacks exploit these vulnerabilities, targeting developers, their infrastructure, and third-party code suppliers to introduce malicious code [39]. Key vectors for these attacks include code repositories, software build pipelines, and distribution channels. A prime example is the 2020 SolarWinds cyber incident, which compromised the Orion software and impacted thousands of organizations, reflecting a significant rise in software supply chain attacks, with a 742% increase from 2019 to 2022 [40]. Additionally, there is a growing concern that generative AI, particularly LLMs, might create new attack vectors by introducing security vulnerabilities in the code they generate.

2.3. LLM Code Generation with Behavioral Learning

Generative AI, specifically LLMs, can be optimized to mitigate LLM-related risks [17]. Fine-tuning techniques are used to improve their learning behaviors in specific aspects of coding, such as functional code generation, program synthesis, vulnerability analysis,

Research Questions

- **RQ1:** How well can diverse LLMs generate secure code across various programming challenges in zero-shot scenarios?
- **RQ2:** To what extent do LLMs understand and apply best practices and address vulnerabilities after using ICL security patterns in one-shot and few-shot learning?
- **RQ3:** How do PDCG LLMs like ChatGPT-4 and Google Bard compare to CCP LLMs like GitHub Copilot and Code Whisperer in generating secure code and adapting to ICL security contexts?
- **RQ4:** What security code smells persist after employing ICL security patterns in one-shot and few-shot scenarios, and what are the potential security risks?

Figure 4: Research Questions

and code repair [24]. Updating LLM weights and parameters or modifying training architectures can improve performance on downstream tasks like coding. ICL improves the learning of LLMs by using examples to enhance code accuracy and security without requiring retraining or adjusting parameters, unlike heavy-weight fine-tuning employing forward computation [41]. Through ICL LLMs are able to behave as meta-gradients³ via attention mechanism.

The learning of LLMs can be improved through Chain of Thought (COT) reasoning process. Chain of Thought reasoning is a powerful strategy for enhancing the LLMs' performance on complex tasks [42, 43]. It involves a series of intermediate reasoning steps, breaking down a problem into smaller, more manageable components, and applying sequential processing. LLMs arrive at the final prediction for tasks such as code generation. By using CoT reasoning, LLMs can effectively learn to solve problems step-by-step, even with zero to few-shot examples. This approach helps LLMs develop a deeper understanding of the task at hand, making them more self-aware and capable of producing more accurate and contextually relevant outputs, especially in code generation tasks. It allows developers and users to improve learning behaviors, particularly in the context of security [25, 17]. This research paper utilizes the ICL method employing COT-based reasoning to improve LLM contextual learning during code generation, aiming to reduce potential security weaknesses in software development. [26].

2.4. Research Problem and Motivation

As the reliance on software in critical systems continues to grow, it becomes crucial to ensure that the code powering these systems is secure and reliable. Traditionally, software development has been driven by human coders, but human-driven software design can

lead to vulnerabilities, making software systems susceptible to cyber attacks. With the assistance of automated code completion and other tools, human coders are now able to increase productivity. In this regard, generative AI-driven language models i.e. (LLMs) aim to automate coding tasks and enhance productivity; however, studies have shown that code generated by LLMs may contain vulnerabilities that attackers can exploit, leading to sophisticated cyber attacks [6, 24]. It has become evident that developers are often unaware of LLM-driven security weaknesses due to the lack of proper testing and code reviews [13, 44]. The integration of LLMs with their various styles of code generation, such as prompt-driven natural language instructions and coding copilots working alongside human developers, adds another layer of complexity to modern software development ecosystem. This potentially adds new attack vectors to future software supply chains for enterprises and critical infrastructures [38, 39].

In the introduction Section (1), we identified gaps in our understanding of security risks associated with LLM code generation. This research aims to evaluate how different machine learning models embed and apply security knowledge to produce secure code. It will also explore the potential for LLM-generated code to introduce new vulnerabilities or unintentionally replicate existing ones during the code generation process. Additionally, it will examine the learning behaviors of LLMs with ICL patterns using chain of thought reasoning methods to aid in the secure and safe usage of these code generating LLMs. By identifying and addressing these security challenges early in the software development stages and embedding security knowledge during the LLMs for code generation, we can ensure that LLM-generated code is a valuable tool for software development rather than a new vector for software supply chain vulnerabilities.

This research aims to enhance the safety and security of software systems by examining the use of AI-based code automation tools by searching for answers to various research questions. The main objective is to

³In LLMs, using ICL as meta-gradients allows models to adapt their learning directly from examples during operation. They adjust parameters based on specific input using the attention mechanism to focus and learn from the most relevant parts of the input, essentially fine-tuning their responses in real-time.

decrease the likelihood of cyber attacks on critical systems. This study will provide insight into and solutions for the security risks linked to LLM code generation. Before implementing LLM-based code generation, it is essential to investigate how different LLMs react to user inputs in various scenarios when solving programming problems. By understanding these aspects, vulnerabilities in LLM-generated code can be identified and mitigated before being integrated into software development pipelines. This experimental research will address the research questions (RQ) defined in Figure 4.

3. Related Work

The early research focused on fundamental code generation tasks in natural language processing (NLP). Over time, there has been a shift from using recurrent neural networks (RNNs) to advanced Transformer models in deep learning for code generation. Initially, studies concentrated on language models such as BERT and RoBERTa. A survey by researchers in [1] provided an in-depth analysis of BERT language model code generation and understanding performance. Furthermore, GPT-Neo and similar models were evaluated for their capability to convert human developer inputs into executable code by the authors in [2, 3]. They also delved into CodeGPT application to complex coding problems and compared its effectiveness against other contemporary models using standardized datasets.

3.1. Baseline LLMs Software Vulnerabilities

Baseline or foundation LLMs in the form of prompt-driven code generators have been extensively tested across various programming languages, including Python, Java, and JavaScript. These models aim to solve multiple programming challenges, ranging from simple function implementations to complex system-level programming [22]. A survey by Zheng et al. [1] discusses the effectiveness of models like CodeGPT and PALM in generating code from complex queries. The survey highlights their adaptability in zero-shot, one-shot, and few-shot learning environments [23]. Despite their proficiency in producing syntactically correct code, these models often fall short of security standards. They frequently exhibit code security smells and vulnerabilities [8].

Hussien et al. [22] conducted a study to develop benchmarks for evaluating security vulnerabilities in code generated by black-box language models. They used a proximity inversion technique to train LLMs for code generation and explored how few-shot prompts can lead to different vulnerabilities. Houry et al. [45] assessed ChatGPT ability to generate secure code across five different programming languages. They later evaluated its potential to mitigate the identified vulnerabilities. Similarly, another study [46] examined ChatGPT capability to generate secure hardware-level code. The study utilized ten different prompts designed

around various CWEs to experiment with secure and insecure hardware code generation using ChatGPT.

3.2. Coding Copilots and Vulnerabilities

With the introduction of Codex and various versions of GPTs, Coding Copilots (CCPs), which are fine-tuned LLMs, have been integrated into programming environments and evaluated for their effectiveness in real-world software development scenarios. Research by Sarsa et al. [44] explored Codex use in educational settings, particularly its real-time code auto-completion and the generation of programming exercises, highlighting its potential to enhance learning experiences. Jacob et al. [47] examined the capabilities of LLMs in program synthesis across general-purpose programming languages, noting the variable effectiveness of these models in producing syntactically and functionally correct code.

Further, a comprehensive evaluation of a GPT language model, fine-tuned on publicly available code from GitHub, was conducted by authors in [13]. Their findings emphasize the model's tendency to suggest insecure code, underscoring the importance of rigorous security assessments.

Regarding secure coding practices, few studies have assessed the ability of fine-tuned LLMs to produce secure code. Pearce et al. [6] first tested Codex, employed within GitHub Copilot, focusing on security through static code analysis to identify CWEs in generated code. Gustavo et al. [7] conducted a user study to assess the security implications of GitHub Copilot code completions by comparing it with code produced by human developers in the C programming language. They found that while CCPs can sometimes reduce bug rates depending on the problem complexity, they often also introduce vulnerabilities. In a related study, Asare et al. [4] evaluated GitHub Copilot performance against human coders in generating code for selected C and C++ problems. Their tests showed that Copilot occasionally introduced new vulnerabilities during code generation and was influential in suggesting more secure code compared to human developers in some cases.

3.3. Significance of our Approach to Related Work

Our research focuses on using custom LLM applications to enhance security in code generation. We differentiate between PDCGs and CCPs, which have interconnected learning behaviors and secure code generation capabilities. Existing studies often overlook this distinction. Additionally, research evaluations typically use a single problem set, neglecting a broader assessment of LLMs across diverse software application scenarios.

Our study compares two types of LLMs for code generation, considering developers' personas. We provide opportunities to learn about security behaviors

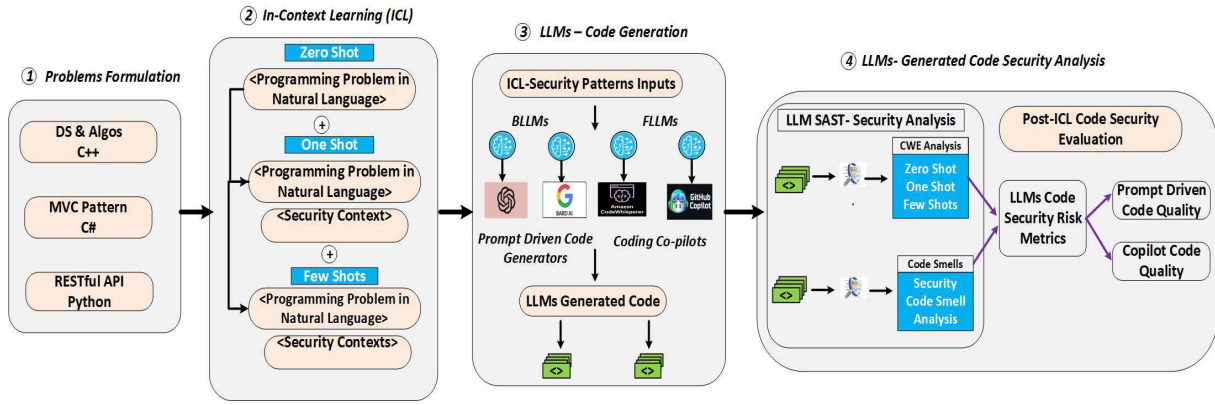


Figure 5: Large Language Models Code Evaluations Framework using ICL Security Patterns

through ICL security patterns involving natural language inputs with incremental security knowledge. This differs from other research in that code generated by LLMs with opportunistic learning behaviors is used to acquire security knowledge dynamically. Our security evaluation is thorough, going beyond Static Application Security Testing (SAST) to examine security code smells after learning. This approach differs from previous studies that only focus on SAST evaluation. We have addressed a broader range of programming issues, and our results emphasize the potential and limitations of using LLMs for critical code security and functionality assessments.

4. Proposed Approach

Our method for evaluating and enhancing the security of LLMs generated code comprises five stages, as shown in Figure 5. These stages include problem formulation, development of ICL security patterns, generation of LLMs code using ICL patterns, and comprehensive security evaluations and analysis. We describe each stage in the subsections below.

4.1. Programming Problems Formulation

As the first step of our proposed approach, we curate a range of diverse problem sets [48, 49, 50, 51]. In order to enhance evaluations for secure code generation, we include three different sets of problems and programming languages: Data Structures and Algorithms (DS & Algos) for fundamental programming problems, API development, and MVC design patterns for medium to advanced application development. We focus on C++, Python, and C# due to their widespread use in application development and relevance to the TOP 25 CWEs and OWASP Top 10 security risks [52, 53, 49]. Our programming problem dataset draws from various open-source competitions, such as LeetCode, and includes API and design pattern problems that reflect current security trends [49, 50, 51]. The importance of assessing LLMs in these areas is highlighted by the increasing security risks associated with

RESTful APIs and web applications using MVC design patterns [54].

4.2. LLMs Tuning-In-Context Learning

In the second stage of our approach, we develop in-context learning patterns to improve LLMs secure coding behaviors. The in-context learning method is a lightweight approach that enhances the learning context of LLMs during code generation through implicit fine-tuning. This approach educates LLMs on secure coding practices by using security examples and operational context to enhance their security knowledge and application abilities. The ICL patterns utilize chain of thought reasoning to provide security examples to LLMs [42, 43]. Security-aware ICL is especially helpful for improving the contextual behavioral learning of coding LLMs. Applying ICL TO programming task enables the LLM to enhance its understanding of security by analyzing the context and examples provided. In this regard Chain of thought reasoning further augments this process by guiding the LLM through a logical sequence of steps, helping it secure code generation. This method enables LLMs to better understand and replicate desired behaviors by providing specific examples within the input context, potentially leading to the generation of safe and secure code [17, 26].

The ICL security pattern comprises three learning scenarios: Zero-Shot, One-Shot, and Few-Shot. These scenarios are examples of embedding security knowledge from well-known standards such as OWASP ASVS and NIST CSDF-driven security principles [55, 56]. The ICL examples progressively improve LLMs' secure coding abilities and adapt to various applications' security requirements, ensuring adequate training across Prompt-Driven and Coding CoPilot LLMs [57]. It is particularly interesting to investigate if incorporating security-focused inputs through ICL can reduce, maintain, or potentially introduce additional security vulnerabilities in the generated source code. An example of the ICL security pattern, which guides securing passwords using various encryption mechanisms, is presented in Figure 6. This example aims

In-Context Learning (ICL) Security Pattern for LLMs (PDCGs and CCPs)

ICL Security Pattern Example

Zero-Shot Learning

- **Description:** LLM Generates code based on pre-existing knowledge without specific examples on security.
- **LLM Input:** Generate a hash function to securely convert plain text into a fixed-size hash value, ensuring data integrity and security.

```
function hashFunction (password) {
    return hash(password);}
```

↓ Contextual Reasoning - LLM

One-Shot Learning

- **Description:** LLM is provided with a single example to demonstrate secure coding practices.
- **LLM CoT-Reasoning:** The provided hash function is vulnerable because it doesn't include a salt, which makes it susceptible to rainbow table attacks.
- **LLM Input- One Security Example:** Develop a secure hash function using salt.

```
function secureHashFunction(password, salt) { // use salt
    return hash(password + salt);}
```

↓ Contextual Reasoning - LLM

Few-Shot Learning

- **Description:** LLM receives multiple secure coding examples illustrating a range of security contexts.
- **LLM CoT-Reasoning:** Using only salt is not sufficient for ensuring security. We need to use unique salts and other security measures like encryption and input validation.
- **LLM Inputs- Multiple Security Examples:**

```
// Use uniqueSalt with password
function secureHashFunction(password, uniqueSalt) {
    return hash(password + uniqueSalt);}
function encryptData(data, key) {
    return encrypt(data, key); } // Use AES with key expansion
function validateUserInput(input) {
    return sanitizeInput(input); } // Prevent SQL injections
```

Figure 6: Illustration of In-Context Learning (ICL) Security Pattern for LLMs utilizing different learning strategies with contextual reasoning.

to educate LLM about password security by gradually applying cryptographic principles from the ground up. ICL patterns can be applied to programmers of varying skill levels, from novices to experts. While this article doesn't use these personas during code generation, it suggests that such roles should be considered in ICL security patterns.

4.3. LLMS Code Generators Selection

The third step involves generating ICL-based codes using various LLMs. We have selected a range of popular LLMs based on the Transformer architecture, which developers, researchers, and students widely use. These LLMs support code generation through NLP prompts and coding copilots that offer code completions and recommendations. Our selection includes ChatGPT⁴

⁴At times, We shall be using the term ChatGPT, which represents ChatGPT4 in this article.

Table 1

Selected LLM Code Generators: Models, Code Generation, and Integration Support

LLM Code Generator	LLM Model Details	Key Features	Integration & Prog. Lang. Support
OpenAI ChatGPT4 (PDCG)	GPT-4.0 multi-model (1.76T Parameters), code context window 32768 tokens	Code generation with input instructions.	API Integration, multiple languages supported (C++, Python, C#, Php, Java)
Google Bard (PDCG)	PaLM 540B parameters, Context Window 1000+ tokens	-Do-	-Do-
Amazon Code Whisperer (CCP)	Model name not disclosed, Billions of Parameters	Code Generation, Completion, Design Suggestions, Dynamic Contextual Learning	Supports cloud infrastructures, IDEs via APIs integration of multiple languages and frameworks (C++, Python, C#)
GitHub Copilot (CCP)	Codex 12B Parameters, Context Window 4096 Tokens	-Do-	-Do-

[58], which has recently been extended from GPT-3.5, and Google Bard, which is now known as Google Gemini [10, 59]. These are prompt-driven code generators. We have also chosen GitHub Copilot [13] and Amazon Code whisperer [20, 60] as coding copilots. ChatGPT4 and Google Bard utilize pre-trained BLLMs, while the copilots use FLLMs. Details on these generators, their LLMs, training datasets, and supported languages are listed in Table 1. It is worth noting that ChatGPT4 is trained on vast datasets, including programming languages, while GitHub Copilot and Amazon Code Whisperer are fine-tuned on programming examples. The study aims to examine the quality of these models' security output and how it varies.

4.4. LLMs Generated Code Security Evaluations

In the final phase of our proposed approach, we conduct security testing and quality evaluations of LLM-generated code. Various tools and methods are used for source code security testing and analysis, ranging from static and dynamic code analysis to compositional analysis, appropriate for distinct stages of the software development lifecycle [61, 36]. Static code analysis is preferred for early detection of security vulnerabilities and examines code structure and syntax during the development phase [62, 63, 56]. In contrast, preferred for early detection of security vulnerabilities, it examines code structure and syntax during the development phase. The choice of security code testing depends on the development phase, the nature of the application, and resource availability. We have selected static testing along with code reviews for LLMs-generated code evaluations to explore source code weaknesses and hidden smells, respectively.

Security Code Static Analysis. To ensure the security of our code, we have implemented the Static Application Security Testing (SAST) approach [36, 64, 65]. This method meets our specific requirements and adheres to industry standards. It evaluates security

vulnerabilities in LLM-generated code through ICL patterns (Zero, one, and few shots) using tools that reference the MITRE CWE Database [66] and the National Vulnerability Database for a comprehensive risk assessment. During our experiments, we utilized the **Snyk Security Code Analyzer** [67] in combination with the Amazon **AWS security scanning API** [68] to evaluate the security of our code. To ensure that we cover all of our programming languages during these evaluations, we integrated an AI SAST analyzer (**Sixth SAST**) [69], which is based on the GPT language model, as a plugin through its API in our VS code IDE. **Hidden Security Code Smells.** The SAST-based analysis is a valuable technique for detecting code security issues but has limitations. To complement SAST, security code smell analysis is used to identify LLMs' poor coding practices that could lead to vulnerabilities in the long run, [70]. Code smell analysis helps identify subtler yet significant potential issues that could compromise security in the long run. These issues may include structural problems not immediately detected by SAST-driven tests. In our evaluation, we focused on the ICL-post code generated, where we selected a few shots generated from the ICL codebase for security analysis. This approach provides a more accurate evaluation of code quality by addressing immediate vulnerabilities and underlying issues [36, 37].

LLM Code Security Risk Assessment. We have developed a metric named **Code Security Risk Measure (CSRM)** to evaluate the code quality generated by LLMs and ensure that it adheres to secure-by-design principles. The CSRM quantitatively measures the security risks associated with LLM-generated code by using source code from few-shot learning to compare and evaluate code from Post-ICL against problem sets of LLM-generated code. The metric considers the Lines of Code, CWEs, and code smells to provide a standardized approach to assess code quality and evaluate the security risks associated with LLM-generated

code. Here is the formal definition of CSRM:

$$CSRM = \left(\frac{\sum(CWEs + CSmell)}{\sum LOC} \right) \times 100 \quad (1)$$

Where:

- LOCs denote the total lines of code generated by the LLM.
- CWEs denote the total count of weaknesses identified in the generated code that match entries in the CWE.
- CSmells denote the total number of identified code smells.

$$CSRM = \left(\frac{\sum_{i=1}^n (CWE_i + CSmell_i)}{\sum_{j=1}^m LOC_j} \right) \times 100 \quad (2)$$

This generalized description of CSRM reflects the sum of multiple modules indexed by i and j for CWEs, code smells, and lines of code applicable to diverse programming problems.

The CSRM metric gauges the level of risk associated with software vulnerabilities. This metric considers both the severity and frequency of occurrence of these indicators. A higher CSRM score indicates a greater risk of exploitation by attackers. This score assists developers and organizations in prioritizing remediation efforts and comparing LLM-generated code across diverse problem sets to identify the most pressing issues. The CSRM is a comprehensive tool that enhances software security by guiding targeted improvements in code quality and vulnerability management.

5. Experimentation

This section will provide an overview of the experimental setup used for code generation. This includes LLMs utilized, the programming datasets chosen, the integration with source code IDEs, and the approach to security testing. Furthermore, we describe how the ICL security patterns were implemented in the programming problems during the code generation process across four different LLMs.

5.1. LLM Platforms and Security Tooling

Code Generation Tools. Our study utilized four different LLM code generators, categorized as PDCGs and CCPs in Table 1. The code produced by PDCG LLMs, including ChatGPT and Google Bard, was exported to Visual Studio Code for analysis. On the other hand, all code generated by the copilots, namely GitHub Copilot and Code Whisperer, was created within the Visual Studio Code IDE and saved in local repositories for additional examination.

Security Tools. We used multiple security tools to assess our codebase for vulnerabilities, including Snyk

Security Analyzer and Snyk Security API for SAST, Code Whisperer built-in security scan, and an AI plugin for static code analysis. Around 80% vulnerabilities were identified using the Snyk Analyzer and AWS code scanner integrated into Visual Studio Code IDE. An AI-based code assistant was also utilized for additional vulnerability detection. These tools effectively identified critical vulnerabilities, including those listed in the MITRE Top 25 Most Dangerous Software Weaknesses and the OWASP Top Ten, such as SQL injection and broken access control, addressing multiple CWEs [52, 53].

5.2. Programming Datasets

Our programming problem datasets are notably diverse, ranging from Data Structures and Algorithms to Design Patterns and RESTful API development. Across these programming problems, we conducted 60 experiments for each problem set using LLM code generators applying ICL security patterns with three instances containing zero, one, and a few shots-based inputs to LLMs. A summary of the programming datasets generated through our experiments is provided in Table 2.

Data Structures and Algorithms. To study Data Structures & Algorithms (DS & Algos.), we used programming problems from LeetCode and Geeks-forGeeks. We chose to implement these problems using C++ because it is a widely used programming language popular among both beginners and experienced developers. To test the effectiveness of LLMs in generating safe and efficient code for data structures and algorithms, we selected three distinct problem sets. This problem set is designed to test a broad range of skills and include different programming challenges.

- Wildcard pattern searching,
- Management of sorted linked lists,
- SQL De-duplication (SQLDD) programming problems.

MVC Design Pattern. We assess the security of MVC (Model-View-Controller) design pattern implementations in C# applications, particularly those generated by LLMs. Leveraging problem sets from C# Corner, we developed an MVC-based C# application, utilizing LLMs for code generation. Our analysis rigorously examines the generated model, view, and controller classes. This approach allows us to delve into the security aspects of LLM-generated code within practical application development, specifically focusing on managing user contact information.

RESTful API Design. Designing a secure RESTful API can be challenging due to widespread use and potential vulnerabilities in development. In our project, we used Python with Flask to create a News API that utilizes LLMs. This API provides endpoints for integrating, modifying, and managing news content

Table 2

Programming Task Descriptions and Details

Problem Set	Task Descriptions	Difficulty Level	Programming Language	# Experiments
DS & Algos	Wildcard pattern matching uses * to match any sequence of characters, including empty sequences.	Medium	C++	12 ICL-based code generation via prompt-driven and coding copilot LLMs
DS & Algos	Merge two sorted linked lists from input files into one.	Medium to High	C++	-Do-
DS & Algos	SQL query to remove duplicate emails and keep the ones with the smallest ID in the table 'Emails.'	High	C++	-Do-
Design Patterns	A C# app that uses the MVC architecture to manage contact info via model, view, and controller classes.	Medium	C#	-Do-
API Design	A RESTful News API with multiple endpoints for CRUD operations.	High	Python	-Do-

on platforms while addressing common vulnerabilities with essential security features. We prioritize critical security aspects and refer to industry standards like the OWASP API Security Top 10 when used with ICL across LLMs.

5.3. ICL Security Pattern-Based LLM Code Generation

We used In-Context Learning (ICL) security patterns to guide the code generation of ChatGPT and Google Bard for all three problem sets mentioned earlier. We also demonstrated the code generation of LLMs for programming problems such as wildcard pattern matching and sorted linked lists. To achieve this, we provided detailed instruction-based inputs to the models.

5.3.1. Prompt Driven Code Generators

LLMs receive natural language and code-based input queries inspired by NIST Secure Software Development Framework (SSDF) and OWASP ASVS. The model is trained using gradual inputs of one and few-shot examples.

ChatGPT4 Code Generation. ChatGPT4 engagement with the wildcard pattern matching algorithm illustrates a progression from a fundamental approach in zero-shot as inputs, referring to 7. It receives multiple examples with a chain of thought-based instructions emphasizing security in a few-shot scenario. The figure

shows further refinement in the security approach, such as adding input validation for the 'pattern' variable to ensure it only contains allowed characters and using a configuration file instead of hardcoded values for sensitive data.

The learning process of ChatGPT LLM involves the addition of secure code related to input validation and sensitization to mitigate SQL injection threats. This is illustrated on the left side of Figure 7.

Google Bard Code Generation. Similarly, the performance of the Google Bard model improves with ICL security patterns, as illustrated in Figure 7, providing step-by-step reasoning as chain of thoughts. The security principles are applied in handling memory for sorted linked lists. During code generation, with one-shot, LLM initially focuses on memory deallocation to prevent memory leaks, an essential security and stability concern in C++ programs. As the learning progresses to Few Shots, Google Bard integrates additional security checks, such as file and directory validation routines. These checks safeguard against directory traversal and ensure data integrity when reading from files.

5.3.2. Coding CoPilots Code Generation

Integrating ICL Security Patterns into coding copilots significantly improves the dynamic security context within the IDE. This allows models (GitHub Copilot and Code Whisperer) to seamlessly incorporate

Prompt Driven LLMs for Code Generation with ICL Security Patterns



Figure 7: ICL Code Generation with ChatGPT and Google Bard LLMs: LLM inputs are provided in natural language text with ICL coding examples and contextual reasoning steps for security. Code is generated afterward

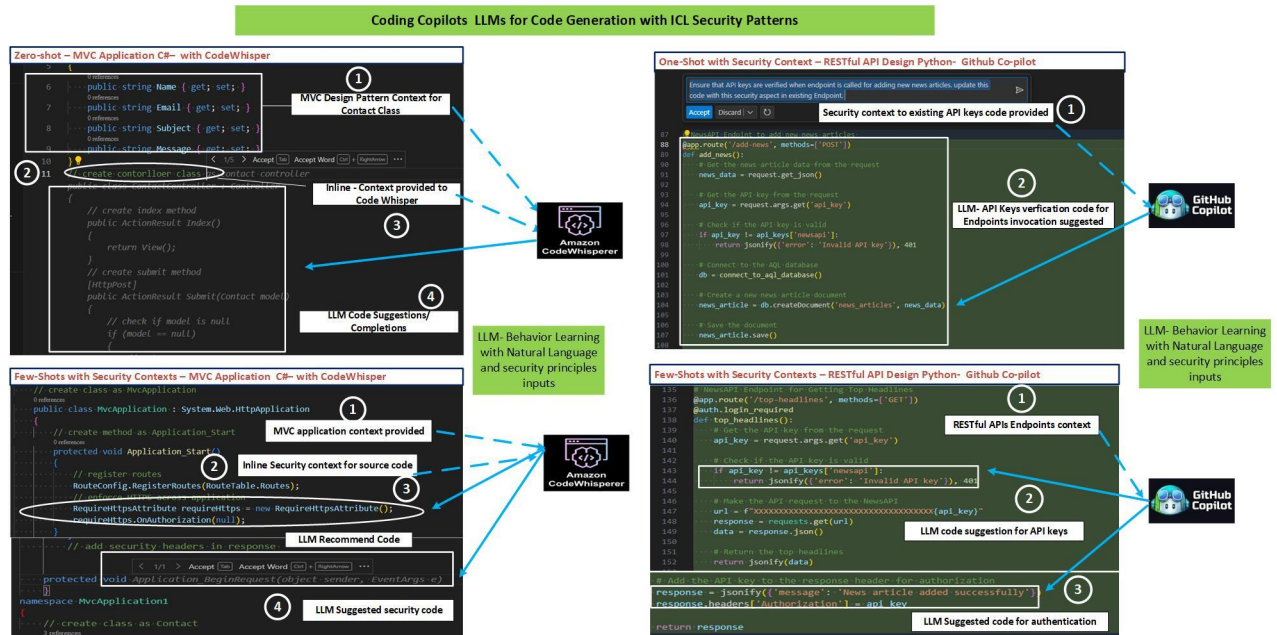


Figure 8: Coding Copilots dynamic contextual learning with ICL: Code Generation of GitHub Copilot and Code Whisperer

these patterns into their code generation processes and gradual learning behaviors. This approach ensures that the generated code adheres to high-security standards. To illustrate, we have included a sample of source code generated through coding copilots below.

GitHub Copilot - RESTful API Development

Using GitHub Copilot, we enhanced the security of a news API by validating API keys during endpoint calls to prevent misuse and reduce the risk of MiTM attacks. This sophisticated code generation process extends beyond conventional single-prompt instructions and is depicted on the left side of Figure 8.

Code Whisperer - MVC Design Pattern

Code Whisperer application in MVC design pattern development begins with setting the initial coding context with a Contact class in the C# program. Code whisperer LLM learning starts with a zero-shot context; it generates MVC controller classes based on comment inputs and inline code, as shown on the right side of Figure 8. Interactive and context-aware inputs enhance security, including enforcing HTTPS and integrating security headers into the codebase, demonstrating the dynamic interactions between developer inputs and AI capabilities.

Table 3

Zero Shot: Coding Vulnerabilities Discovered in Programming Problems

Coding LLMs	DS & Algos (C++)				MVC (C#)	Pattern	RESTful (Python)	API
	WildCard	Sorted List	Linked	SQL DD				
ChatGPT	5	4		5	5		7	
Google Bard	4	4		4	5		6	
GitHub Copilot	8	4		4	6		7	
Code Whisperer	4	7		5	7		6	

6. Results and Analysis

This section examines the code generated in response to the research questions posed in subsection 2.4. Our goal is to evaluate the reliability and security of the code produced by LLMs, focusing on its trustworthiness through various ICL patterns used in programming scenarios. Our results are derived from research questions and obtained through a two-stage security analysis. We employed both SAST and code security examinations to identify security issues in the code. We used the MITRE CWE database to analyze the generated code and detect known vulnerabilities. We evaluated CWEs based on their associated severity levels to pinpoint potential security risks in the generated code that could be exploited in cyber attacks.

6.1. LLMs Code Generation with Zero Shot

The first research question (RQ1) seeks to answer whether LLM code generators can produce functional code securely. To find the answer to RQ1, we further divide this question into two sub-parts:

- Zero-shot code generation with prompt-driven code generators.
- Zero-shot code generation with Copilots.

The code generated by the LLMs in Table 3 is not secure, as numerous vulnerabilities are found in each LLM with zero shots. In total, 111 CWEs were discovered, with an average of around six vulnerabilities observed in each set of generated programming code. For instance, Code Whisperer and Github Copilot each produced 29 vulnerabilities, with the code related to MVC pattern and RESTful API having a higher number of CWEs. ChatGPT-4 and GitHub Copilot also produced more CWEs (5 and 7, 6 and 7, respectively) for MVC Pattern and RESTful API code. The code generation did not consider security context, only simplified input prompts for each problem set. This indicates that when these LLMs generate code based on functional requirements, they tend to produce insecure code, potentially leading to threats and allowing adversaries to exploit vulnerabilities and launch sophisticated attacks.

Vulnerabilities Distribution. We have identified 111 coding vulnerabilities in the source code generated

by LLMs in the first iteration with zero shots. We have selected frequently occurring or prominent CWEs found in each programming dataset. Please see Table 4 for more information. In ChatGPT, CWE-20 (Improper Input Validation) was observed in its generated code for both DS & Algos and the MVC Pattern. This vulnerability could lead to SQL injection, XSS, and command injection attacks. Google Bard has shown vulnerabilities such as CWE-89 (SQL Injection), which appeared twice in the generated code algorithms. Attackers could exploit this vulnerability to manipulate database queries and potentially access or corrupt data. GitHub Copilot generated code included CWE-22 (Weak Path Traversal Validation), which could allow attackers to access unauthorized files. Code whisperer is prone to using risky functions like CWE-676, which can lead to buffer overflows and other critical errors.

6.2. RQ2: Secure Code Generation - One and Few Shot Learning

With our second research question, RQ2, we seek to determine the impact of ICL security pattern applicability on generated code security. We aim to discover if ICL one-shot and few-shot security-aware prompts and contexts can train LLMs during the code generation process to produce secure code. For this purpose, we created 20 unique ICL one-shot patterns for each LLM to address problem sets and generate separate programs. In our few-shot ICL experiments, we included multiple ICL security examples in each pattern, with at least two examples based on secure coding principles in a few shots.

It is essential to understand that prompt-driven language models like ChatGPT and Google Bard learn differently from coding copilot language models. Prompt-driven models learn continuously within dynamic IDEs by analyzing code contexts, comments, and selections, especially when applying ICL security patterns to programming problems. After implementing ICL security measures in the coding of LLMs, the generated code indicates that the LLM is now equipped with an understanding of security principles and attempts to interpret NLP instructions for enforcing security during code generation. However, the learning behavior of

Table 4

LLMs Generated Code Frequent Vulnerabilities Distribution Across Problem Sets with DS & Algo has Three Instances of Programming Problems

ChatGPT Zero Shot Frequent Vulnerabilities					
CWEs	Descriptions	Count	Programming Problems		
			DS & Algos	MVC Pattern	RESTful API
CWE-20	Improper Input Validation	4	3	1	0
CWE-22	Insecure Path Traversal	2	2	0	0
CWE-676	Use of Dangerous Functions	2	2	0	0
CWE-200	Information Exposure	3	1	1	1
Google Bard Zero Shot Frequent Vulnerabilities					
CWEs	Descriptions	Count	Programming Problems		
			DS & Algos	MVC Pattern	RESTful API
CWE-89	SQL Injection	2	1	1	0
CWE-200	Exposure of Sensitive Information	2	0	1	1
CWE-20	Improper Input Validation	2	2	0	0
GitHub Copilot Zero Shot Frequent Vulnerabilities					
CWEs	Descriptions	Count	Programming Problems		
			DS & Algos	MVC Pattern	RESTful API
CWE-22	Weak Path Traversal Validation	2	2	0	0
CWE-89	SQL Injection	2	0	1	1
CodeWhisperer Zero Shot Frequent Vulnerabilities					
CWEs	Descriptions	Count	Programming Problems		
			DS & Algos	MVC Pattern	RESTful API
CWE-759	Weak Encryption (One Way Hash without Salt)	2	0	1	1
CWE-352	Information Exposure	2	0	1	1
CWE-676	Use of Dangerous Functions	3	3	0	1
CWE-89	SQL Injection	2	0	1	1

an LLM depends on its underlying Foundation Model architecture, Training Dataset, and other vital features; therefore, after a few shots, each LLM exhibits different security-aware behavior with the ability to generate secure code. Another aspect is the coverage provided by few shots of ICL security contexts.

One Shot ICL Security Analysis. Instructions for one-shot security contexts, accompanied by at least one example that adheres to security best practices and principles (as referenced in the code generation Figures 7, 8) are provided to code generators. Integrating one-shot ICL security patterns into programming problems reduces vulnerabilities within code generated by language models. For instance, applying a one-shot pattern to a wildcard problem through ChatGPT-4 and conducting security tests can decrease the number of vulnerabilities from five (observed after a zero-shot attempt) to three (after one-shot implementation). This improvement is demonstrated in the context of CWE-20, which concerns improper input validation. By adding a one-shot security context that includes file name sanity checks and input format verification, as illustrated by the code snippet for wildcard pattern in C++:

Listing 1: One-shot code enhancement with ICL

```

1  /* Ensure file names are sanitized:
2  isValidFileName (String FileName) */
3  if (!isValidFileName(inputFileName) || !
4      isValidFileName(outputFileName)) {
5      std::cerr << "Invalid file name!" <<
6      std::endl;
7      return 1;
8  }

```

Here, the risk of injection attacks targeting the application is minimized. The secure code generated by the ChatGPT-4 model reflects improvement after being trained in security contexts. Sometimes, even after applying a one-shot security pattern, the vulnerabilities remain unchanged or lead to another vulnerability. For instance, Google Bard zero-shot generated code for a sorted linked list was vulnerable due to improper memory release. This security weakness mitigated by using the memory cleanup function through an ICL one-shot context in the code:

Listing 2: LLM: Memory Management

```

1  // clean memory for Node* mergeLists(Node*
2  list1, Node* list2).
3  int main() {...
4  cleanupMemory(list1);

```

Can We Trust Large Language Models Generated Code?

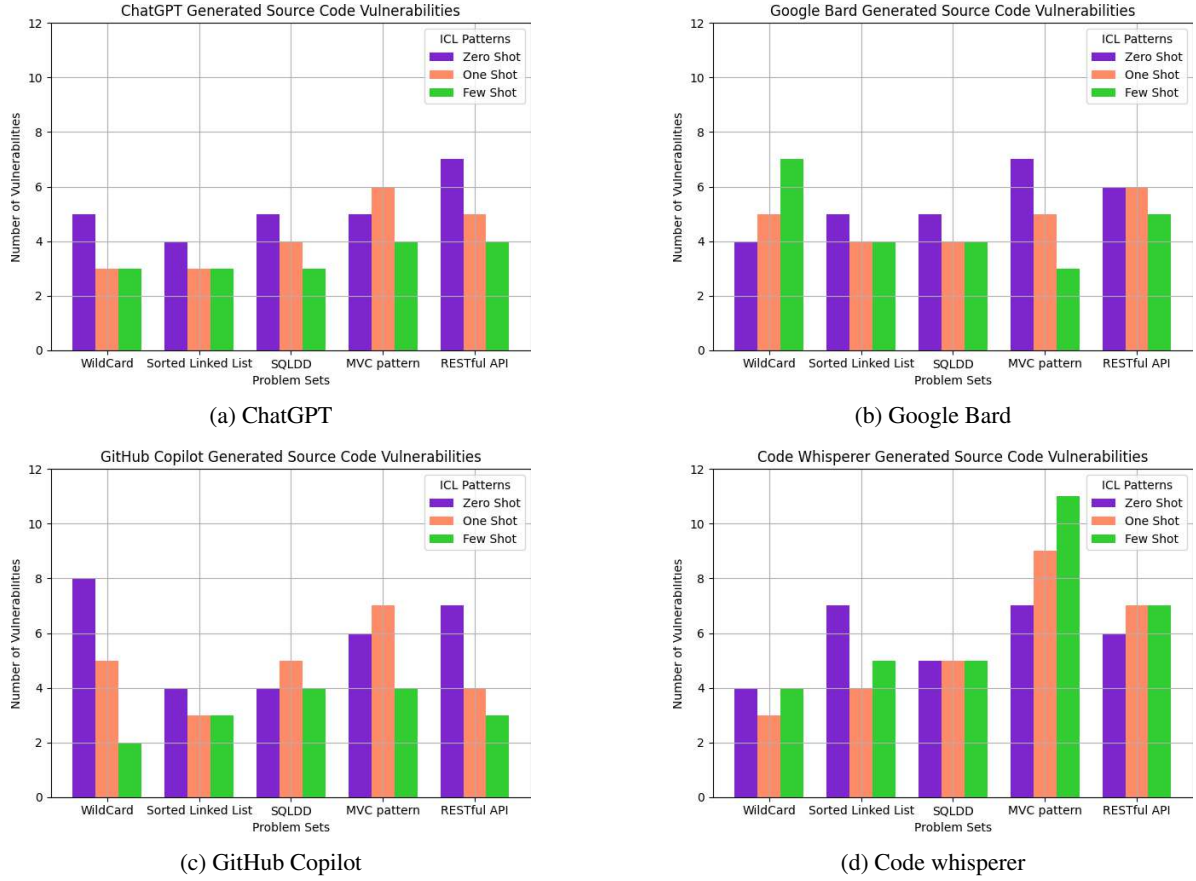


Figure 9: Comparison of Vulnerabilities Generated by ChatGPT, Google Bard, GitHub Copilot, and Code Whisperer

```
4 cleanupMemory(List2);
5 return 0; }
```

However, the above mitigation did not address the related CWE-400 vulnerability involving uncontrolled resource consumption of related variables in memory. **Few Shot ICL Security Analysis.** ICL security patterns, when provided through multiple examples, enable coding LLMs to understand security principles better and generate more secure code. These LLMs effectiveness can vary, with some producing more secure code (as shown in the vulnerability analysis graphs in Figure 9). Offering LLMs a more comprehensive array of security examples than the one-shot ICL pattern provides them with a broader security context. For example, when using GitHub CoPilot to create code for the MVC pattern in C#, multiple security contexts learned from the initial one-shot ICL pattern were provided. Instructions to generate code that verifies API keys when API endpoints are called were included, thus mitigating CWE-307 related to weak API key validation. Even though we have provided extensive security guidance for the LLMs, vulnerabilities continue to exist in certain parts of the code. For instance, when utilizing GitHub Copilot for a RESTful API, there were still API design issues due to incorrect resource permission assignments, such as managing API keys. Please refer to the provided context and generated code below.

Listing 3: API Security- Few shots ICL

```
1 # Providing API keys hard-coded is not safe
2 # Load API keys from a file for security
3 API_KEYS = {}
4 # Open(API keys file) as storage variable
5 with open('api_keys.txt') as f:
6     for line in f:
7         key, value = line.strip().split(':')
8         API_KEYS[key] = value
```

This leads to CWE-732 and the lack of encryption of sensitive data during data transmission at runtime. Moreover, saving keys in plain storage is risky, where an attacker potentially can gain unauthorized access due to the lack of key validation.

LLMs using a few-shot ICL security pattern often learn a broader context of security when generating code compared to one-shot attempts and strive to address security weaknesses more effectively. The coding copilot GitHub learns incrementally about security contexts with few-shot experiences and, over time, suggests more secure lines of code. Meanwhile, prompt-driven code generators like ChatGPT and Google Bard learn about security context specific to the programming problem area within the source code without thoroughly covering security aspects, leading to security vulnerabilities.

6.3. RQ3: Comparative Assessment of LLMs for Vulnerabilities

This section seeks answers to RQ3: How do prompt-driven LLMs compare to coding Copilot in generating secure code and adapting to ICL security contexts? To answer this, we conduct a vulnerability analysis among these two classes of LLM platforms and assess their code safety and security performance during code generation.

ChatGPT and Google Bard We start with PDCGs LLMs and refer to the graphs in Figures 9a and 9b. In a comparative zero-shot scenario, Google Bard generated slightly fewer CWEs than ChatGPT (4 and 5, respectively), with a notable exception in the RESTful API problem, where Bard performed better. Bard also demonstrated a better initial understanding of security in the context of MVC patterns, suggesting a firmer foundational grasp of security concerns. On the other hand, ChatGPT outperformed in the Wildcard, sorted linked list, and SQLDD programming scenarios with a lower number of vulnerabilities.

In the shift to one-shot learning, we observed more significant variations in performance. The Google Bard vulnerability count increased for the Wildcard and RESTful API from 5 to 6, while ChatGPT performance remained generally stable or improved. This suggests that single examples may be used more effectively to enhance code security. During the few-shot learning phase, both models showed significant improvements. However, Bard exhibited a notable increase in vulnerabilities within the Wildcard problem set, indicating potential differences in multiple examples' integration and application methods to enhance security.

GitHub Copilot and Code Whisperer. The vulnerabilities demonstrated by GitHub Copilot and Code Whisperer, as visualized in Figures 9c and 9d across problem sets, showcase their efficacy in learning to handle security issues. Initially, Copilot showed weakness in the WildCard domain, with 8 and 6 CWEs from zero to one shot, while Code Whisperer struggled with SQL Duplicate vulnerabilities, staying at 5. The GitHub model improved with one-shot to few-shot learning, reducing CWEs from 5 to 4 and 3 to 2, especially in the MVC pattern and RESTful API domains. As the learning advances to few-shot scenarios, both language models exhibit reduced vulnerabilities. Copilot has significantly strived in RESTful API and MVC problems, whereas Code Whisperer has shown marked improvements in SQL Duplicate and MVC scenarios. Despite increased context learning from zero to a few shots, vulnerabilities persist, highlighting the ongoing challenge of fully securing automated code generation.

ICL Patterns Addressing Coding Weaknesses.

1. Prompt Driven Code Generators. The evolution of ChatGPT and Google Bard in addressing CWE-20 vulnerabilities through various learning scenarios: Zero

Shot, One Shot, and Few Shots. Initially, both models exhibit minimal input validation. ChatGPT relies on simple model state validations within an MVC design pattern, and Google Bard lacks integer validations in a sorted linked list program. This early approach demonstrates a fundamental gap in proactively addressing security vulnerabilities without specific guidance.

Addressing CWE-20 vulnerabilities through ICL, both ChatGPT and Google Bard have shown significant progress from basic to more sophisticated input validation techniques across different learning scenarios. Initially, ChatGPT4 approach within an MVC design pattern in C# primarily relied on simple model state validations. Through Few Shots learning, it implements more comprehensive security measures by adding validation attributes to model properties, signifying a deeper understanding of secure coding principles.

Listing 4: ChatGPT4 Vulnerabilities Management

```
1 [Required]
2 [StringLength(50)]
3 public string Name { get; set; }
```

Google Bard, initially lacking in input validation for a sorted linked list, evolves to include a specific function ensuring integer validation, illustrating its adaptive learning capability:

Listing 5: Google Bard Vulnerabilities Management

```
1 bool integer(string str) {
2     stringstream ss(str);
3     int num;
4     if (ss >> num) { return ss.eof();
5     } else {
6         return false; }}
```

These examples demonstrate both models' ability to enhance code security by incorporating detailed validation checks, reflecting an improved capacity to generate secure code in response to explicit security instructions.

2. Coding Copilots. Generated code by GitHub Copilot initially included hardcoded API keys, which led to CWE-798. The introduction of a one-shot learning scenario directed Copilot to externalize API key storage, as reflected in the following code snippet:

Listing 6: One-shot learning for secure API key loading in GitHub Copilot.

```
1 API_KEYS = {}
2 with open('api_keys.txt') as f:
3     for line in f:
4         key, value = line.strip().split(':')
5         API_KEYS[key] = value
```

Despite advancements with few-shot learning, GitHub Copilot inadvertently introduced a lower severity CWE-259 related to hard-coded credentials. Conversely, Code whisperer progression in few-shot learning enabled the loading of secret keys from the environment, as seen in the snippet below:

Listing 7: Few-shot learning for environment-based secret key loading in Codewhisperer.

```
app.config['SECRET_KEY'] = os.getenv('SECRET_KEY')
```

Furthermore, Code Whisperer secured API key invocation by implementing a decorator function, enhancing its security measures against CWE-798.

Vulnerabilities Severity Levels

This section describes the severity levels of vulnerabilities associated with LLM-generated source code. We will conduct a comparative analysis between our coding LLMs. The classification of CWEs into high, medium, and low severity levels is fundamental for evaluating and managing software vulnerabilities CWE severity levels [71]. High-severity vulnerabilities require immediate intervention to prevent significant breaches. Below, we will analyze vulnerabilities in two categories of LLMs:

1. PDCGs Severity Levels. We have conducted a comparative analysis of vulnerability severities between PDCGs (ChatGPT and Google Bard). In the case of ChatGPT, the majority of vulnerabilities are within the Low to Medium severity spectrum, numbering 26 and 21, respectively (refer to Figure (10a)). These vulnerabilities mainly stem from programming datasets for Data Structures & Algorithms. They are characterized by issues such as path traversal, the use of potentially unsafe functions, and lapses in input validation. Additionally, RESTful API components are associated with higher severity levels, including CWE-311 (Missing Encryption of Sensitive Data), CWE-319 (Cleartext Transmission of Information), and CWE-811 (SQL Injection), which underscore vulnerabilities that could facilitate injection attacks.

The Google Bard platform displays various vulnerability severities, including 10 High, 21 Low, and 39 Medium severities, as shown in Graph (10a). Among these, vulnerabilities such as CWE-327, which addresses the use of insecure cryptographic algorithms, and CWE-522, denoting the unauthorized exposure of sensitive information, are particularly concerning. These High-severity vulnerabilities pose significant risks to system security and data protection, emphasizing the need for robust security measures, especially in production environments where such code is deployed.

2. Copilots Severity Levels. The security impact assessment comparing the vulnerability severity levels of CCPs (GitHub Copilot and Code Whisperer) reveals significant differences. The analysis indicates that GitHub Copilot has fewer high-severity vulnerabilities, which are categorized into high (7), medium (26), and low (30) levels. Please refer to the Graph in Figure 10b to visually represent these findings.

In copilots, most of the high-severity issues are found in Data Structures & Algorithms and RESTful APIs, including notable vulnerabilities such as SQL Injection CWE-89 and Missing Release of Resources. Although these vulnerabilities are less severe, they still

pose a risk if not adequately managed, making Copilot generally safer for specific coding tasks but not without its risks. On the other hand, Code Whisperer displays a broader range of severity, with 33 high-severity vulnerabilities. This indicates a greater likelihood of generating problematic code, particularly in Data Structures & Algorithms and RESTful API code. The vulnerabilities include Path Traversal CWE-22 and Out of Bounds Write CWE-787. This suggests that the code generated by Code Whisperer may pose higher security risks, highlighting the need for thorough security measures.

LLMs Vulnerabilities Reduction Capability

Here, we present an empirical analysis detailing the reduced vulnerabilities achieved through implementing ICL security patterns in LLM-generated code.

1. Vulnerabilities Reduction - CCPs. The graph in Figure (11a) illustrates the percentage reduction of vulnerabilities from Zero Shot to Few Shot for both Github Copilot and Code Whisperer across different software concepts. Github Copilot shows significant vulnerability reductions, particularly in the Wildcard (75%) and MVC Pattern (33%) categories, suggesting potential for further improvement with more data or training. However, smaller reductions in the Sorted Linked List and SQL Duplicate categories (25% and 0%, respectively) indicate limited initial vulnerabilities or that additional examples did not improve learning. An increase in vulnerabilities in the RESTful API category (-17%) raises concerns about potential issues in model learning or complexity-induced vulnerabilities. Code Whisperer achieves significant vulnerability reductions in the Sorted Linked List (29%) and RESTful API (57%) categories, outperforming Github Copilot in API-related vulnerabilities, possibly due to better learning from more examples. Yet, it experiences a notable vulnerability increase in the Wildcard category (-57%) and no change in the SQL Duplicate category (0%), indicating challenges in complex problem-solving and consistent performance across problem types.

2. Vulnerabilities Reduction - PDCGs. Examining vulnerability reductions in Graph (11b) from zero to few-shot learning for ChatGPT and Google Bard CWEs across programming problems provides valuable insights. ChatGPT shows a broad ability to decrease vulnerabilities, with the most notable reduction in RESTful API vulnerabilities at 42.86 %, suggesting a solid understanding of API-related security issues. Other areas like Wildcard, SQL Duplicate, and Sorted Linked List also see reductions, indicating effective learning from additional examples.

Conversely, Google Bard displays an increase in vulnerabilities for the Wildcard category by 75 %, implying challenges in mitigating or possibly exacerbating vulnerabilities with more input. However, it excels in the MVC Pattern category with a 57.14 % reduction, highlighting its strength in addressing design pattern vulnerabilities. Other categories show mixed results,

Can We Trust Large Language Models Generated Code?

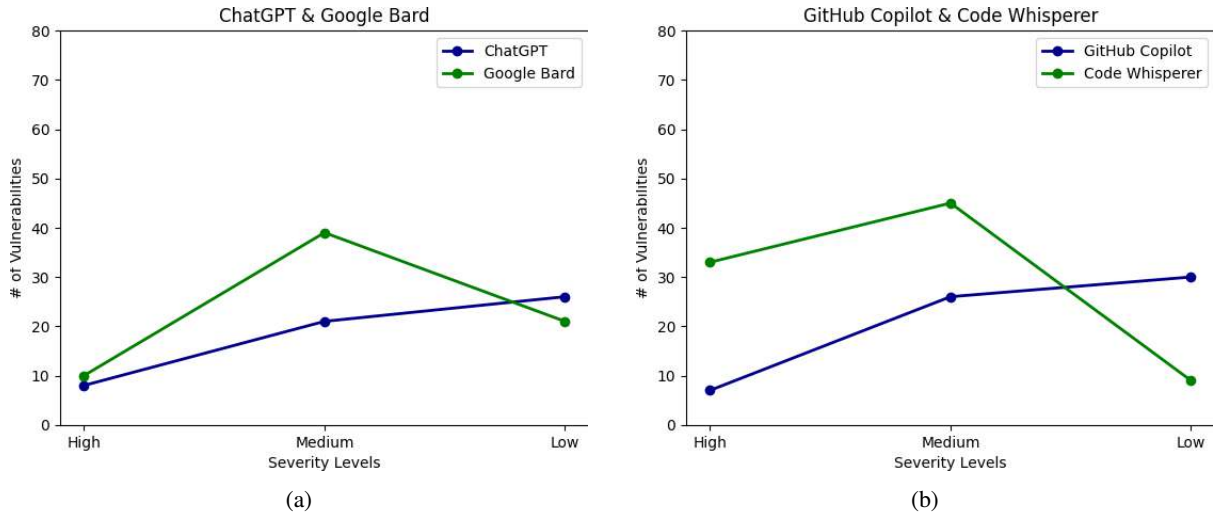


Figure 10: Security impact analysis from vulnerabilities

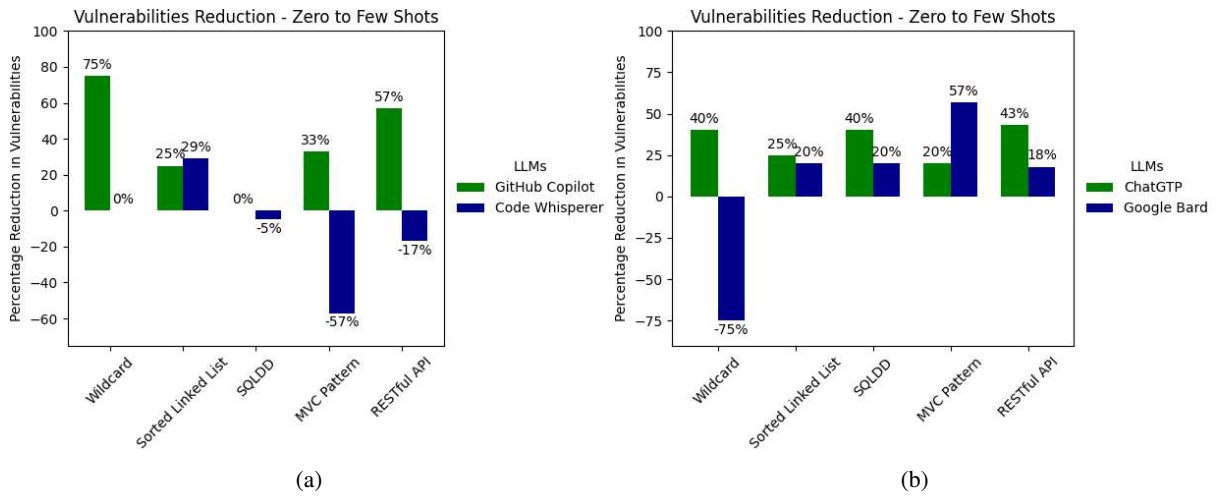


Figure 11: LLMs Code Vulnerability Reduction Analysis for LLMs- ICL security patterns

with moderate reductions in vulnerabilities, illustrating varied effectiveness across different programming contexts.

6.4. RQ4: Assessing the Presence of Code Smells in Source Code

The fourth research question investigates source code smells related to security in LLM outputs post-ICL-based security learning. The goal is to determine the extent of safe and secure code production. We will examine hidden code smells or bugs in few-shot generated code that complies with ICL security patterns across various LLM code generators. We aim to evaluate how LLMs manage security in their outputs. After a thorough analysis, these code smells will be classified by severity (High, Medium, Low) to provide insights for enhancing security testing and exposing vulnerabilities that may not be apparent through traditional static code analysis.

LLM Generated Code Reliability. We analyzed the presence of code smells in three problem sets using four code generating LLMs, as illustrated in Figure (12a). Our findings indicate that Google Bard and ChatGPT produced more code smells than GitHub Copilot and Code Whisperer. This suggests potential gaps in understanding or implementing secure coding practices using ICL in specific contexts with each LLM. Among all the programming problems, Google Bard consistently had the highest number of code smells, with the maximum number of code smells (9) found in the linked list program. This may indicate that this model training data or algorithms are not optimally tuned for security, even though it applies ICL security patterns. On the other hand, Code Whisperer showed the lowest number of code smells in more straightforward tasks such as Wildcard, but this number increased in complexity-related tasks like Restful API. This pattern might suggest strengths in essential code generation but challenges in more complex scenarios.

Can We Trust Large Language Models Generated Code?

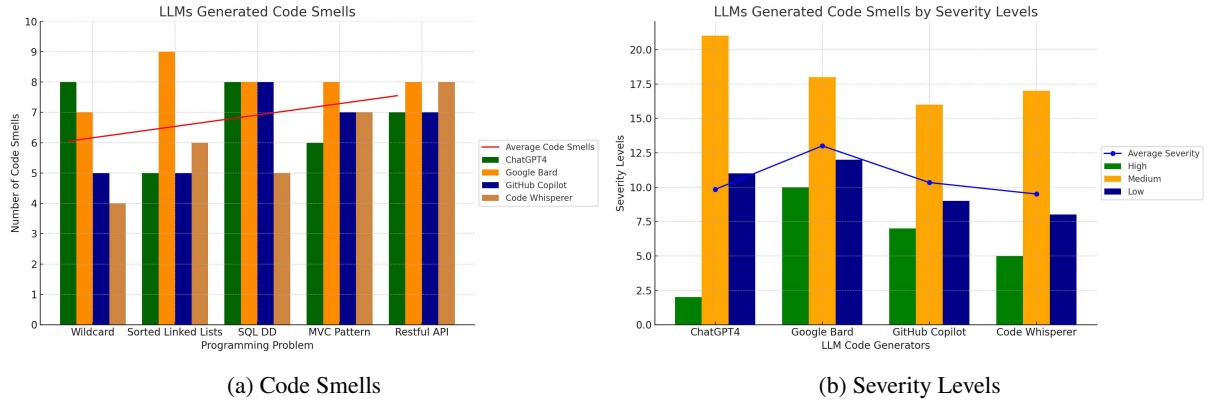


Figure 12: LLMs generated Code Smells and Risks

GitHub Copilot performed moderately well, showing fewer code smells. This suggests a balanced handling of coding tasks in terms of security. Both GitHub Copilot and Code Whisperer had lower code smell occurrences, particularly in critical areas like SQL Database Design and RESTful API. On average, RESTful API and SQL Database Design had the highest number of code smells among the four LLMs, which can vary across problems and affect reliability. We have gathered a random selection of code smells generated by LLMs from PDCGs and CCPs. These code smells and their associated security impacts for each problem set are detailed in Table 5. The severity levels of these code smells significantly influence the overall quality and security of the code. For example, as shown in Graph Figure 12, GitHub Copilot introduces medium-severity security risks with hard-coded database paths. The code listing below exhibits this vulnerability severity taken from SQLDD program generated with GitHub Copilot:

Listing 8: Code Smell Severity in C++

```
1 sqlite3 *db;
2 // SQLite database file name
3 sqlite3_open("Emails.db", &db);
4 sqlite3_stmt *stmt;
```

This vulnerability exposes the system to unauthorized data access, highlighting the importance of dynamic database path configurations to enhance security, especially in the context of DS & Algos.

Similarly, code related to ChatGPT exhibits a direct use of user-controlled input, leading to high-severity vulnerabilities related to arbitrary file access. This critical issue emphasizes the urgent need for stringent input validation to protect system integrity and prevent unauthorized file exposure, particularly relevant in DS & Algo scenarios.

Listing 9: Code Smell lacking integrity

```
1 std::ifstream inputFile(inputFileName);
2 if (!inputFile) {
3     std::cerr << "Error opening input
4     file!" << std::endl;
```

```
4     return 1;
5 }
```

Furthermore, Code whisperer generated code smell depicted here:

Listing 10: API code smell in Python

```
1 @limiter.limit("5 per minute")
```

The code snippet above only applies the rate limit to the login route, which presents a medium-severity security risk within RESTful API practices. This limited application indicates a potential for bypassing rate limits, raising concerns about the risk of Denial of Service (DoS) or brute force attacks. It emphasizes the need for consistently applying rate limiting across all sensitive routes to ensure robust security.

Code Smells Severity Levels. ChatGPT has the highest medium-severity coding smells (21), while Google Bard has the highest high-severity coding smells (10). GitHub Copilot and Code Whisperer have fewer high-severity smells (7 and 5, respectively) and more medium and low-severity smells (16 and 9 for GitHub Copilot and 17 and 8 for Code Whisperer). The analysis indicates that ChatGPT code may require a substantial review to identify potentially disruptive issues. High severity Google Bard coding issues raise concerns about the critical nature of the problems it may introduce, necessitating rigorous code review processes. Meanwhile, GitHub Copilot and Code Whisperer code smells tend to be less critical, reducing the urgency and intensity of the review processes required. The blue line in Figure 12(b) represents the average code smell severity across all models. This line trends downward from ChatGPT to Code Whisperer, indicating an overall improvement in the ability to generate cleaner code from one LLM to another.

Code Smells Security Impacts. Although we used ICL security patterns for secure code generation, the results of the generated code by LLMs show that security code smells continue to emerge. This indicates areas where LLMs still fall short. For example, to mitigate

Table 5

Selected LLMs generated Source Code Smells, related LOCs, and Security Impacts Summary

LLMs	Code Smell	Related LOC	Security Impact	Problem
GitHub Copilot	Hardcoded Database File Path	sqlite3_open("Emails.db", &db);	Inflexible and insecure Database file access.	DS & Algo
	Insufficient Error Handling	if (db == nullptr) ... and other similar checks	Unstable application state or sensitive information exposure.	MVC Pattern
	Improper Use of HTTP Methods	POST and PUT methods in multiple endpoints	Unauthorized modifications lacking validation.	RESTful API
Code Whisperer	SQL Injection Vulnerability	Direct binding user input to SQL statements	May allow SQL injection if inputs are not properly sanitized.	DS & Algo
	Weak Authentication	RequireHttpsAttribute used without checking	Improper implementation leading to MITM attacks.	MVC Pattern
	Potential Rate Limit Bypass	@limiter.limit("5 per minute") Only applied to the login route.	Lacking consistent rate limits can lead to DoS or brute force attacks.	RESTful API
ChatGPT	Potential Arbitrary File Access	std::ifstream in(filename); Using user-controlled input directly	Risk of accessing or exposing unauthorized files.	DS & Algo
	Missing Data Validation	if (ModelState.IsValid)	Vulnerabilities leading to injection attacks/data corruption.	MVC Pattern
	Lack of Input Validation	@app.route functions	Increased risk of malicious input.	RESTful API
Google Bard	Lack of Input Sanitization	email = sanitizeEmail(email); The sanitization is rudimentary.	Insufficient sanitization may leave room for injection attacks.	DS & Algo
	Cross-Site Scripting (XSS)	WebUtility.HtmlEncode(...); Manual input encoding is prone to errors.	Insufficient sanitization of user input.	MVC Pattern
	Insufficient Input Validation	The routes do not explicitly validate input data before processing.	Vulnerable to various injection attacks or unintended behavior.	RESTful API

SQL Injection vulnerabilities (CWE-89), Code whisperer LLM tried to incorporate parameterized queries in its code generation process. However, direct binding of user input to SQL statements was observed, signifying a high-severity SQL Injection Vulnerability (refer to 5 code smell). This suggests that although there was an attempt to improve, essential security practices were not fully implemented or were incorrectly applied, leaving critical vulnerabilities.

Similarly, in addressing Cross-Site Scripting (XSS) risks (CWE-79), Google Bard aimed to sanitize user inputs through mechanisms like `email = sanitizeEmail(email)`; However, this approach resulted in a medium-severity code smell due to a lack of input sanitization, revealing that the sanitization efforts were rudimentary and insufficient to mitigate the risk of XSS attacks effectively.

Overall, the analysis provides insights into the quality and reliability of code generated by these models, and the visualizations help understand LLM-generated code smells with each LLM about programming problems and severity levels.

7. Discussions

This section presents an analytical discussion of the results produced and evaluates their findings concerning the research questions we posed in this study. We also delve into discussions to assess the security of source code generated by LLMs using our developed metrics and examine the overall impact on code quality. Lastly, we critically and scientifically analyze and discuss various factors impacting code quality for LLMs-based code generation.

7.1. Results Synthesis with Research Questions

RQ1: Source Code Security without Security Knowledge Section 6.1 presented results for code generated through zero-shot inputs across LLM platforms. These results corroborate research on the probability of LLMs generating insecure code [6, 8]. All 4 LLMs used in this study contributed to vulnerabilities when given tasks for code generation. These experiments

reveal a substantial gap in the baseline security knowledge of LLMs when generating code without a specific security context (zero-shot). All tested models produced code with significant vulnerabilities, totaling 111 CWEs across different programming contexts. For example, GitHub Copilot and Code Whisperer each produced 29 vulnerabilities, like MVC patterns and RESTful APIs, where most of the CWEs dangerously indicated severe threats and associated attack risks. This quantitative data underlines the inherent risks of deploying such models without additional security enhancements.

We conclude that LLMs' default operation mode prioritizes functional output over secure output, necessitating explicit security training or guidelines for secure coding practices.

RQ2: Adaptation to ICL patterns (One-Shot and Few-Shot Learning) Our research on code generation using LLMs found that adapting to security requirements through methods like one-shot and few-shot learning has shown promising but varied results. One-shot learning, where a single security example is provided, often leads to a significant but partial reduction in vulnerabilities. For example, when implementing security measures in ChatGPT, focusing on input validation reduced the number of vulnerabilities from five to three. However, this approach does not uniformly address all potential security flaws.

When transitioning to few-shot learning, language models are provided with multiple examples of security contexts to improve their depth and breadth of understanding. For instance, when GitHub CoPilot was used to generate code for the MVC pattern in C#, instructions derived from multiple one-shot experiences were applied to ensure that API keys were verified when API endpoints were called, addressing vulnerabilities such as weak API key validation (CWE-307). Despite this enhanced security approach, some vulnerabilities may persist, as evidenced by persisting vulnerabilities (CWE-732). This vulnerability persisted after a few shots of training the LLM.

The examples mentioned highlight an important point. While one-shot learning can lay the groundwork for security considerations in LLMs, it may not have the depth to address all security aspects fully. On the other hand, few-shot learning, which provides multiple examples, allows for a broader and more detailed understanding, potentially leading to more secure outputs. However, neither method ensures the complete elimination of vulnerabilities, emphasizing the complex challenge of incorporating comprehensive security requirements into LLMs. The varying effectiveness of instructional contexts suggests the need for continuous refinement of training approaches to better adapt to the evolving landscape of security needs in LLM code generation.

RQ3: Are certain LLMs better at generating secure code? In our analysis in subsection 6.3, we presented how different LLMs perform when generating code. Comparing pre-trained models like ChatGPT and Google Bard with coding copilots like GitHub Copilot and Code Whisperer reveals differing strengths and weaknesses. Coding copilots with downstream code generation composed of fine-tuned LLMs showed better dynamic adaptation to security contexts, likely due to their interaction with ongoing coding activities and immediate feedback loops. In contrast, pre-trained models struggled more with generalization and required more direct and explicit ICL security patterns to produce secure code. Our findings suggest that few-shot learning is more effective than zero and one-shot ICL patterns in reducing vulnerabilities in LLMs. The degree of improvement varies depending on the model and context. Still, in general, few-shot learning produces better results due to the richer context it provides for learning and applying security measures. ChatGPT and Copilot demonstrate improvements with few-shot learning, while Google Bard's performance varies across different programming scenarios. The language model exhibits a unique trend where few-shot learning significantly reduces vulnerabilities, especially in SQL injection and MVC pattern contexts, but vulnerabilities increase in the WildCard context. Interestingly, vulnerabilities increase from one-shot to few-shot in the WildCard context, indicating a model-specific learning anomaly.

We calculate the average reduction of vulnerabilities across problem sets for each LLM and then measure the reduction ratio for each. It is important to note that the complexity of individual programming problems might have affected the learning ability of LLM through ICL. GitHub Copilot had the most significant reduction at 38%, followed by ChatGPT at 34%, Google Bard at 23%, and Code Whisperer at 6%. Inconsistencies across models show varying effectiveness in learning security principles, especially in more complex scenarios like MVC patterns and RESTful APIs. The analysis suggests that prompt-driven language models (PDCGs) and coding copilots (CCPs) have reduced vulnerabilities through few-shot learning. Coding copilots, such as GitHub Copilot and Code Whisperer, may be more effective in integrating and applying security measures. The learning behavior of prompt-driven language models and coding copilots under ICL conditions showed different adaptations to security contexts. ICL effectively enhances the security of language model-generated code, but not all security principles are equally learned or applied. Future work should focus on optimizing ICL strategies for broader and more complex security scenarios.

RQ4: Security Smells and Code Reliability We detailed code smells for each programming scenario in subsection 6.4 post ICL for each few-shot learned generated program instance. Code smells have uncovered a

significant number of medium and high severity issues across different LLMs, quantitatively indicating various associated risks. For example, GitHub Copilot and Code Whisperer showed a high frequency of medium-severity vulnerabilities, requiring stringent security audits and highlighting the potential risk of deploying LLM-generated code without thorough validation.

The research findings demonstrate the average occurrence of code smells in various coding LLMs. This reveals distinct patterns and provides insights into how well each model has integrated security knowledge to produce secure code. ChatGPT consistently performs with a slight increase in code smells, suggesting a moderate absorption of security knowledge, stable but imperfect outputs, and potential for improvement to minimize security flaws. Google Bard displays variability, with code smells increasing and then decreasing, indicating a learning curve in understanding security concepts and inconsistent integration of security knowledge across coding challenges. Performance for GitHub Copilot varies significantly by problem type, with noticeable improvement in certain areas but struggles in others. It shows effective internalization of security practices for specific problem sets and areas where security knowledge application is lacking. Code Whisperer produces the most complex outputs and the highest and most variable code smell counts, suggesting significant struggles with consistently integrating security knowledge and indicating a high-risk, high-reward scenario in its coding solutions. Overall, the effectiveness of each LLM in generating secure code appears correlated with their ability to apply learned security knowledge consistently across different programming problems. More consistency and fewer code smell peaks indicate more effective security integration, principles.

The study highlights the prevalence of medium to high-severity coding smells in the LLMs output, emphasizing the need for improved security practices and tools to address these subtler security risks.

7.2. Generated Code Security Implications

In this section, we measure the security implications of the code generated by LLMs using our CSRM metric, as defined in Section 4.4. The CSRM, defined in equation 2, is used to evaluate the post-ICL security risks for both prompt-driven and coding copilots, and the results are visualized in Figure 13a. After conducting security testing, we calculate CSRM values using the CWE and code smells. The security implications of our findings are discussed in detail below.

1. Generated Code Security Risks. The given graph depicts the CSRM values of four LLMs against various coding domains, highlighting different risk profiles. It shows that ChatGPT has higher security risks (20%) in data structures and algorithms. At the same time, Google Bard has increased risks (14%) in RESTful

API implementations, indicating different strengths in secure coding practices across problem sets. GitHub Copilot has relatively low security risks (8%) for SQLDD and MVC patterns, whereas Code Whisperer has higher security risks both for SQLDD and MVC patterns (13%, 10%), indicating security risks associated with each LLM have different thresholds from problem to problem. Therefore, while numerical metrics like CSRM are indicative, they must be considered alongside the nuanced improvements that ICL provides. Optimizing ICL for each problem set is crucial as it allows for a more directed and effective learning path for each LLM.

The CSRM assessments assist developers in prioritizing their code security features, particularly in areas with higher risks. By identifying specific vulnerabilities, the CSRM metric helps direct remedial actions aimed at strengthening the secure-by-design principles essential for maintaining robustness against potential exploitations in LLM-generated software.

2. Generated Code Quality by LLMs. We utilized linear regression on CSRM data to examine security risk trends for two types of LLMs: PDCGs and CCPs. To simplify this analysis, we converted categorical data into a format appropriate for mathematical modeling. We developed a linear model to identify patterns in the data, concentrating on the overall code quality. The analysis results are displayed in a chart titled LLMs Generated Code Security Risks and can be found in Figure 13b. This chart thoroughly examines how PDCGs and CCPs handle security risks across different coding problem sets. Such an analysis is crucial for system development as it highlights these various LLMs' security awareness and adaptive learning behaviors. Additionally, it helps to ensure security when utilizing these LLMs.

During the analysis, it was observed that moving from DS & Algorithms to RESTful APIs resulted in a significant drop in the impact on code quality for PDCGs. The effect on code quality decreased from 15% to 11%, suggesting PDCGs may be better suited for handling RESTful APIs, as they are optimized for web-based environments where endpoint interface security is crucial. However, when CCP LLM platforms handle more complex or interactive tasks, such as RESTful APIs, they exhibit a slight upward trend in security risks, impacting code quality by over 10%.

These findings highlight the challenges of maintaining secure coding practices in feature-rich commercial software. The analysis of LLMs shows that foundation models like PDCGs exhibit different behaviors and may be prone to security vulnerabilities. Fine-tuned models for CCPs show increasing security risk ratios in complex environments, indicating the challenges of maintaining secure coding practices. Tailored security strategies based on LLM categories and specific coding tasks are necessary to mitigate risks. Researching

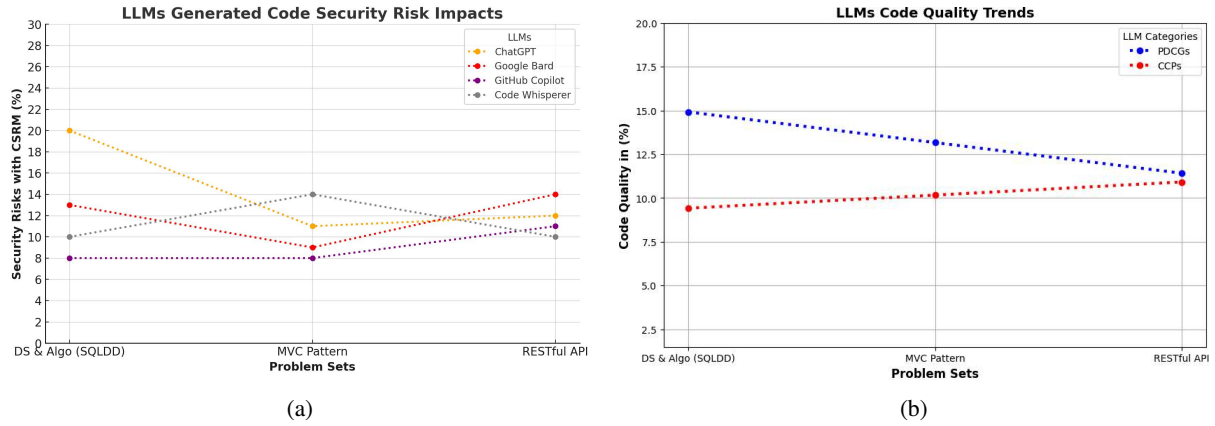


Figure 13: LLMs impact on security risks and code quality.

factors for better LLM security in particular contexts is crucial for refining and ensuring safer tool applications.

7.3. LLMs, ICL, and Security Risks

In this subsection, we will discuss the correlation between the ICL security patterns used to embed security knowledge in LLMs and the associated security risks of the generated code.

Implications of ICL Security Patterns We discuss the impact of ICL security patterns on the ability of LLMs (Language Model Models) to learn about security. Understanding how these approaches affect code security across various problem sets is essential for generating code through ICL using security learning patterns such as one-shot, zero-shot, and few-shot learning. We aim to examine the effectiveness of these ICL patterns in addressing security risks associated with the code generation process and to what extent these patterns can teach LLMs about security principles.

Although LLMs have equal opportunities to learn about security through one, zero, and few shots learning patterns, we have observed varying security risks between PDCGs and CCPs in our study. This difference may indicate variations in how efficiently each LLM internalizes and applies security knowledge based on the type and level of examples provided during the learning phase.

Learning Pattern Limitations. It has been observed that when using LLMs to generate code, in some cases, one-shot and few-shot learning based on ICL may not always provide complete exposure to a broad spectrum of security issues. This requires ICL security patterns as domain-specific, fully instructed with targeted programming language security principles knowledge. As described earlier, incomplete learning outcomes can result in security risks in the code generated by LLMs. Similarly, zero-shot learning heavily relies on the pre-training dataset and architecture, which may not have covered specific security practices relevant to the examined problem sets. Despite the

security measures integrated into ICL, there are challenges in converting learning patterns to low-risk code outputs from code-generating LLMs. These difficulties are heightened in complex settings or problematic areas, such as RESTful APIs for CCPs and high-risk initial settings in DS & Algos for PDCGs. To minimize the chances of generating code with severe vulnerabilities, it is essential to customize the outputs of LLMs to promote secure code patterns and discourage known vulnerabilities.

7.4. LLMs Training Architectures and Source Code Security.

It is crucial to analytically describe the factors that could lead to security vulnerabilities in code generated by LMs. We will discuss these factors below.

Training Data Quality The presence of outdated or vulnerable code, deprecated libraries, and poor security practices in the training data can lead to less secure or directly vulnerable code. In our study, despite using a few-shot learning approach employing ICL with multiple security examples, LLMs still exhibited security weaknesses in our experiments. Similarly, malicious code patterns in the training source code can seep into LLM outputs as code smells. The coding copilots (GitHub Copilot and Code Whisperer) LLMs used in our experiments are fine-tuned on code containing hidden security patterns with bad data, such as undeclared variables and the absence of exception handling within particular programming language datasets. Our study also highlights this problem, as code smells were found in almost all the generated code with severe security bugs. Despite aiding developers in generating more functional lines of code, automated code generation through prompt-driven and coding copilots comes with diverse security problems in the form of CWEs and coding smells, adding to the overall attack surface of the systems deploying this code in production lines. It is important to sanitize bad source code quality training datasets for LLMs, where underlying vulnerabilities and code smells must be repaired and fixed before

this data is used for model learning. Using this code for deployment without integrating systematic security testing and reviews is dangerous for system security and trustworthiness.

Inherent Model Biases. Pre-training biases and limitations in model training data can lead to security oversights [17, 8], especially when the data lacks diverse examples of secure coding practices across various contexts. Specifically, models like Google Bard and Code Whisperer have shown heightened vulnerabilities in certain problem sets, suggesting a learning bias or a deficiency in recognizing specific security threats. This issue is particularly concerning in environments with limited secure coding examples. We observed that vulnerabilities persisted in various programming problem scenarios despite providing LLMs with explicit examples of security issues. For example, when instructed an LLM to enhance the security of an MVC pattern by transforming a vulnerable SQL query into a parameterized query. The LLM successfully modified the SQL query but failed to address security issues in the surrounding code. This suggests a learning bias in these models, where a lack of comprehensive security knowledge leads to persistent security weaknesses. The observed increase in vulnerabilities for LLMs in certain scenarios underscores a learning bias or a gap in understanding specific vulnerabilities, highlighting the importance of rigorous model training.

A mix of fine-tuning methods can be used to tackle these issues, including instruction tuning and security guidance based on the RAG [26], explicit instruction fine-tuning [72, 12, 73] approach customized for the programming language. Various models may have specific strengths, highlighting the necessity for diverse strategies in AI-powered security for code generation. Including a human feedback loop involving developers with security expertise in model training is vital for safe and secure code generation.

Dependency and Third-party Libraries. LLMs trained on millions of open-source repositories often use third-party libraries with outdated code. The code generated by LLMs depends heavily on these third-party libraries used during training, which may contain vulnerabilities [5]. As a result, the generated code inherits third-party security risks. This problem becomes more challenging in static environments and cannot automatically detect issues with library versioning or security updates, particularly with code generation methods such as the prompt-driven style used in ChatGPT. However, this issue persists with both types of coding LLMs, including coding copilots. Our study found that LLMs may include calls to third-party libraries with vulnerabilities during code generation. For example, in RESTful APIs, the security of libraries managing HTTP requests, data parsing, or service interactions is crucial. Similarly, in the MVC pattern, code generation often relies on these third-party libraries and API calls, which can harbor

security weaknesses, leading to vulnerabilities in the generated code.

Security Challenges and Developers Experience Levels

Developers' experience levels may influence the security of LLM-generated code and their understanding of security practices [74, 5]. For instance, inexperienced programmers using LLMs to generate C++ code for tasks like Data Structures and Algorithms may overlook essential security practices, leading to vulnerabilities such as CWE-20 (Improper Input Validation) and Buffer Overflow. As these programmers gain experience and transition to languages like C# and Python, their understanding of security also improves.

Developers using LLMs for C++ code generation may face heightened security risks due to the language's complexity and lack of experience in essential security practices. On the other hand, developers working with languages like C# in structured environments may encounter different security challenges, such as information leakage or improper error handling [75]. For example, they encounter misconfigurations in multiple interacting components, leading to information leakage (CWE-200) or improper error handling (CWE-705). More experienced programmers dealing with complex API development in Python must address advanced security issues, such as weak authentication mechanisms (CWE-307) and insufficient input validation (CWE-20). Developers must be educated in secure software development practices, including language-specific cybersecurity principles following the OWASP Top 10. Additionally, developers must understand how LLMs learn in different contexts in dynamic programming environments to ensure secure code generation.

7.5. LLMs New Source of Software Supply Chain Vulnerabilities

Our experiments show that code generated by LLMs is potentially a new source of software supply chain vulnerabilities, which is concerning and difficult to handle. The increasing use of LLMs for code generation represents a significant change in modern software development. It allows for quicker production and supports agile and DevOps pipelines through advanced automation and API support. However, AI-driven automated code generation also brings substantial cybersecurity risks. Our findings suggest that the LLMs generated code may introduce more complex attack vectors for systems that use it. As more AI-assisted programming tools are integrated into development ecosystems, LLMs could become new sources of vulnerabilities in software supply chains. Unlike the traditional risks associated with third-party components and libraries, the vulnerabilities from LLMs come directly from the generated code itself.

Our research emphasizes the complex nature of vulnerabilities and hidden code smells, influenced by the learning patterns and training data of LLMs underlying

architectures. Lack of security practices and testing among software development teams also play a role in producing insecure code. While coding LLMs excel in learning diverse NLP tasks like program synthesis and code repair, they generally lack specialized security knowledge about emerging vulnerabilities and hidden code problems. This complexity emphasizes the need for strong security protocols and continuous assessment of LLMs generated code to effectively reduce potential security risks. It is important to ensure that integrating LLMs into software development enhances security rather than compromising it.

8. Conclusions and Future Research Work

Our study rigorously evaluated various coding LLMs to determine their capability to produce secure code. We added security knowledge to LLMs through in-context learning patterns. Our thorough analysis revealed that LLMs exhibited significant vulnerabilities when generating code without any prior security knowledge (zero-shot). However, with in-context learning, they occasionally demonstrated the ability to produce more secure code in specific programming scenarios. Nevertheless, we observed persistent security bugs in different programming instances, even after providing security knowledge. Taking a broader perspective, our findings clearly indicate that coding copilots showed improved performance in specific programming scenarios by learning through dynamic interactions and contextual awareness. When alerted about security issues, LLMs often acknowledged the problems and made attempts to address vulnerabilities. In conclusion, forcefully integrating LLMs into software development signifies a substantial shift, offering rapid development. Yet, this pioneering innovation also presents new challenges, particularly regarding software security. LLM generated code is potentially a new source of source code level vulnerabilities introduced into software supply chains. Addressing these new vulnerabilities demands a comprehensive review of security measures in LLM training and deployment to effectively mitigate these emerging risks.

Our future work aims to improve the security of code generated by LLM by developing techniques to embed secure coding patterns and enhance their ability to recognize security issues in context. We will use our curated datasets to explore methods for fixing vulnerabilities using many-shot learning and retrieval-augmented generation. Furthermore, we will refine LLMs to learn secure coding practices in order to reduce source code bugs. To ensure the trustworthiness and reliability of LLM, we will create language-specific problem sets for comprehensive testing. By taking proactive measures to address security risks, we aim to unleash the full potential of LLMs in software development.

Declaration of competing interest

Authors hereby declare that there is no conflict of interest regarding the publication of this article.

References

- [1] Y. Chang, X. Wang, J. Wang, Y. Wu, L. Yang, K. Zhu, H. Chen, X. Yi, C. Wang, Y. Wang, W. Ye, Y. Zhang, Y. Chang, P. S. Yu, Q. Yang, X. Xie, A survey on evaluation of large language models, *ACM Trans. Intell. Syst. Technol.* 15 (3) (mar 2024). doi:10.1145/3641289.
- [2] F. Christopoulou, G. Lampouras, M. Gritta, Pangu-coder: Program synthesis with function-level language modeling, *arXiv preprint arXiv:2207.11280* (2022). URL <https://arxiv.org/abs/2207.11280>
- [3] Y. Wang, H. Le, A. Gotmare, J. Li, S. Hoi, Codet5mix: A pretrained mixture of encoder-decoder transformers for code understanding and generation (2022). URL <https://openreview.net/forum?id=VPCi3STZca0>
- [4] O. Asare, M. Nagappan, N. Asokan, Is github's copilot as bad as humans at introducing vulnerabilities in code?, *Empirical Softw. Engg.* 28 (6) (sep 2023). doi:10.1007/s10664-023-10380-1.
- [5] Y. Yao, J. Duan, K. Xu, Y. Cai, Z. Sun, Y. Zhang, A survey on large language model (llm) security and privacy: The good, the bad, and the ugly, *High-Confidence Computing* (2024).
- [6] H. Pearce, B. Ahmad, B. Tan, B. Dolan-Gavitt, R. Karri, Asleep at the keyboard? assessing the security of github copilot's code contributions, in: *2022 IEEE Symposium on Security and Privacy (SP)*, IEEE, 2022, pp. 754–768.
- [7] G. Sandoval, H. Pearce, T. Nys, R. Karri, S. Garg, B. Dolan-Gavitt, Lost at c: A user study on the security implications of large language model code assistants, in: *32nd USENIX Security Symposium (USENIX Security 23)*, USENIX Association, Anaheim, CA, 2023, pp. 2205–2222.
- [8] S. Yeo, Y.-S. Ma, S. C. Kim, H. Jun, T. Kim, Framework for evaluating code generation ability of large language models, *ETRI Journal* 46 (1) (2024) 106–117. doi:<https://doi.org/10.4218/etrij.2023-0357>.
- [9] Google AI, PALM 2 Technical Report, Tech. rep., Google AI Research (2023). URL <https://ai.google/static/documents/palm2techreport.pdf>
- [10] Google, An overview of bard: an early experiment with generative ai, accessed: 2023-11-30 (2023). URL <https://ai.google/static/documents/google-about-bard.pdf>
- [11] F. F. Xu, U. Alon, G. Neubig, V. J. Hellendoorn, A systematic evaluation of large language models of code, in: *Proceedings of the 6th ACM SIGPLAN International Symposium on Machine Programming, MAPS 2022*, Association for Computing Machinery, New York, NY, USA, 2022, p. 1–10. doi:10.1145/3520312.3534862.
- [12] I. H. Sarker, Llm potentiality and awareness: a position paper from the perspective of trustworthy and responsible ai modeling, *Discover Artificial Intelligence* 4 (1) (2024) 40.
- [13] M. Chen, J. Tworek, H. Jun, Q. Yuan, H. P. d. O. Pinto, J. Kaplan, H. Edwards, Y. Burda, N. Joseph, G. Brockman, et al., Evaluating large language models trained on code, *arXiv preprint arXiv:2107.03374* (2021).
- [14] M. Verdi, A. Sami, J. Akhondali, F. Khomh, G. Uddin, A. K. Motlagh, An empirical study of c++ vulnerabilities in crowd-sourced code examples, *IEEE Transactions on Software Engineering* 48 (5) (2022) 1497–1514. doi:10.1109/TSE.2020.3023664.
- [15] G. A. A. Prana, A. Sharma, L. K. Shar, D. Foo, A. E. Santosa, A. Sharma, D. Lo, Out of sight, out of mind? how vulnerable

- dependencies affect open-source projects, *Empirical Softw. Engg.* 26 (4) (jul 2021). doi:10.1007/s10664-021-09959-3.
- [16] D. Votipka, K. R. Fulton, J. Parker, M. Hou, M. L. Mazurek, M. Hicks, Understanding security mistakes developers make: qualitative analysis from build it, break it, fix it, in: *Proceedings of the 29th USENIX Conference on Security Symposium, SEC'20*, USENIX Association, USA, 2020.
- [17] Y. Chang, X. Wang, J. Wang, Y. Wu, L. Yang, K. Zhu, H. Chen, X. Yi, C. Wang, Y. Wang, et al., A survey on evaluation of large language models, *ACM Transactions on Intelligent Systems and Technology* (2023).
- [18] OpenAI, GPT-4 Technical Report, Tech. rep., OpenAI (2023). URL <https://cdn.openai.com/papers/gpt-4.pdf>
- [19] R. L. et. al, Starcoder: may the source be with you! (2023). arXiv:2305.06161.
- [20] Amazon Web Services, Amazon codewhisperer, <https://aws.amazon.com/codewhisperer/>, accessed: 2023-09-30 (2023).
- [21] H. Touvron, T. Lavril, G. Izacard, X. Martinet, M.-A. Lachaux, T. Lacroix, B. Rozière, N. Goyal, E. Hambro, F. Azhar, et al., Llama: Open and efficient foundation language models, arXiv preprint arXiv:2302.13971 (2023).
- [22] H. Hajipour, K. Hassler, T. Holz, L. Schönherr, M. Fritz, Codelmsec benchmark: Systematically evaluating and finding security vulnerabilities in black-box code language models (2023). arXiv:2302.04012.
- [23] Y. Li, S. Qi, C. Gao, Y. Peng, D. Lo, Z. Xu, M. R. Lyu, A closer look into transformer-based code intelligence through code transformation: Challenges and opportunities (2022). arXiv:2207.04285.
- [24] H. Pearce, B. Tan, B. Ahmad, R. Karri, B. Dolan-Gavitt, Examining zero-shot vulnerability repair with large language models, in: *2023 IEEE Symposium on Security and Privacy (SP)*, IEEE, 2023, pp. 2339–2356.
- [25] S. Zhang, Z. Chen, Y. Shen, M. Ding, J. B. Tenenbaum, C. Gan, Planning with large language models for code generation, arXiv preprint arXiv:2303.05510 (2023).
- [26] M. R. Parvez, W. Ahmad, S. Chakraborty, B. Ray, K.-W. Chang, Retrieval augmented code generation and summarization, in: M.-F. Moens, X. Huang, L. Specia, S. W.-t. Yih (Eds.), *Findings of the Association for Computational Linguistics: EMNLP 2021*, Association for Computational Linguistics, Punta Cana, Dominican Republic, 2021, pp. 2719–2734. doi: 10.18653/v1/2021.findings-emnlp.232.
- [27] B. Rozière, J. Gehring, F. Gloeckle, S. Sootla, I. Gat, X. E. Tan, Y. Adi, J. Liu, R. Sauvestre, T. Remez, J. Rapin, A. Kozhevnikov, I. Evtimov, J. Bitton, M. Bhatt, C. C. Ferrer, A. Grattafiori, W. Xiong, A. Défossez, J. Copet, F. Azhar, H. Touvron, L. Martin, N. Usunier, T. Scialom, G. Synnaeve, Code llama: Open foundation models for code (2024). arXiv:2308.12950.
- [28] A. Vaswani, N. Shazeer, N. Parmar, J. Uszkoreit, L. Jones, A. N. Gomez, L. u. Kaiser, I. Polosukhin, Attention is all you need, in: *Advances in Neural Information Processing Systems*, Vol. 30, Curran Associates, Inc., 2017.
- [29] S. Kotsiantis, V. Verykios, M. Tzagarakis, Ai-assisted programming tasks using code embeddings and transformers, *Electronics* 13 (4) (2024) 767.
- [30] J. Achiam, S. Adler, S. Agarwal, L. Ahmad, I. Akkaya, F. L. Aleman, D. Almeida, J. Altschmidt, S. Altman, S. Anadkat, et al., Gpt-4 technical report, arXiv preprint arXiv:2303.08774 (2023).
- [31] Y. Wang, W. Wang, S. Joty, S. C. Hoi, Codet5: Identifier-aware unified pre-trained encoder-decoder models for code understanding and generation, arXiv preprint arXiv:2109.00859 (2021).
- [32] J. Finnie-Ansley, P. Denny, B. A. Becker, A. Luxton-Reilly, J. Prather, The robots are coming: Exploring the implications of openai codex on introductory programming, in: *Proceedings of the 24th Australasian Computing Education Conference*, 2022, pp. 10–19.
- [33] D. Guo, S. Ren, S. Lu, Z. Feng, D. Tang, S. Liu, L. Zhou, N. Duan, A. Svyatkovskiy, S. Fu, M. Tufano, S. K. Deng, C. Clement, D. Drain, N. Sundaresan, J. Yin, D. Jiang, M. Zhou, Graphcodebert: Pre-training code representations with data flow (2021). arXiv:2009.08366.
- [34] MITRE, Cwe view: Software development, <https://cwe.mitre.org/data/definitions/699.html>, accessed: 2024-04-23.
- [35] Overview of CVE, <https://www.cve.org/About/Overview>, accessed: YYYY-MM-DD.
- [36] M. Felderer, M. Büchler, M. Johns, A. D. Brucker, R. Breu, A. Pretschner, Security testing: A survey, in: *Advances in Computers*, Vol. 101, Elsevier, 2016, pp. 1–51.
- [37] J. Li, Vulnerabilities mapping based on owasp-sans: a survey for static application security testing (sast), arXiv preprint arXiv:2004.03216 (2020).
- [38] A. Coufalíková, I. Klaban, T. Šlajs, Complex strategy against supply chain attacks, in: *2021 International Conference on Military Technologies (ICMT)*, 2021, pp. 1–5. doi:10.1109/ICMT52455.2021.9502768.
- [39] S. Cordey, Software supply chain attacks: An illustrated typological review, *CSS Cyberdefense Reports* (2022).
- [40] V. Ghariwala, Protecting against software supply chain attacks, InfoWorldAccessed: 2024-02-23 (2024). URL <https://www.infoworld.com/article/3712543/protecting-against-software-supply-chain-attacks.html>
- [41] D. Dai, Y. Sun, L. Dong, Y. Hao, S. Ma, Z. Sui, F. Wei, Why can gpt learn in-context? language models implicitly perform gradient descent as meta-optimizers (2023). arXiv:2212.10559.
- [42] Z. Bi, N. Zhang, Y. Jiang, S. Deng, G. Zheng, H. Chen, When do program-of-thought works for reasoning?, in: *Proceedings of the AAAI Conference on Artificial Intelligence*, Vol. 38, 2024, pp. 17691–17699.
- [43] W. Chen, X. Ma, X. Wang, W. W. Cohen, Program of thoughts prompting: Disentangling computation from reasoning for numerical reasoning tasks, *Transactions on Machine Learning Research* (2023). URL <https://openreview.net/forum?id=YfZ4ZPt8zd>
- [44] J. Finnie-Ansley, P. Denny, B. A. Becker, A. Luxton-Reilly, J. Prather, The robots are coming: Exploring the implications of openai codex on introductory programming, in: *Proceedings of the 24th Australasian Computing Education Conference, ACE '22*, Association for Computing Machinery, New York, NY, USA, 2022, p. 10–19. doi:10.1145/3511861.3511863.
- [45] R. Khoury, A. R. Avila, J. Brunelle, B. M. Camara, How secure is code generated by chatgpt?, in: *2023 IEEE International Conference on Systems, Man, and Cybernetics (SMC)*, IEEE, 2023, pp. 2445–2451.
- [46] M. Nair, R. Sadhukhan, D. Mukhopadhyay, How hardened is your hardware? guiding chatgpt to generate secure hardware resistant to cwes, in: S. Dolev, E. Gudes, P. Paillier (Eds.), *Cyber Security, Cryptology, and Machine Learning*, Springer Nature Switzerland, Cham, 2023, pp. 320–336.
- [47] V. Liventsev, A. Grishina, A. Härmä, L. Moonen, Fully autonomous programming with large language models, in: *Proceedings of the Genetic and Evolutionary Computation Conference, GECCO '23*, Association for Computing Machinery, New York, NY, USA, 2023, p. 1146–1155. doi:10.1145/3583131.3590481.
- [48] LeetCode Problem Set, <https://leetcode.com/problemset/>, accessed: [2024-03-04].
- [49] R. Sun, Q. Wang, L. Guo, Research towards key issues of api security, in: W. Lu, Y. Zhang, W. Wen, H. Yan, C. Li (Eds.), *Cyber Security*, Springer Nature Singapore, Singapore, 2022, pp. 179–192.
- [50] Akamai Technologies, Sans survey on api security, Tech. rep., Akamai Technologies (2023). URL <https://www.akamai.com/site/en/documents/research-paper/2023/sans-survey-api-security.pdf>

- [51] E. B. Fernandez, N. Yoshioka, H. Washizaki, J. Yoder, Abstract security patterns and the design of secure systems, *Cybersecurity* 5 (1) (2022) 7.
- [52] MITRE Corporation, CWE - Top 25 Most Dangerous Software Weaknesses, <https://cwe.mitre.org/top25/>, accessed: 2024-03-02 (2023).
- [53] Open Web Application Security Project (OWASP), OWASP Top Ten Web Application Security Risks, <https://owasp.org/www-project-top-ten/>, accessed: 2024-03-02 (2023).
- [54] K. Greenberg, Akamai survey: Api-specific controls are lacking, *Tech. rep.*, Akamai Technologies (Jul 2023). URL <https://www.techrepublic.com/article/akamai-survey-api-security/>
- [55] OWASP Foundation, Owasp application security verification standard 4.0, accessed: 2023-09-24 (2019). URL https://owasp.org/www-pdf-archive/OWASP_Application_Security_Verification_Standard_4.0-en.pdf
- [56] National Institute of Standards and Technology (NIST), Secure software development framework (ssdf), <https://csrc.nist.gov/projects/ssdf>, accessed: 2024-02-24 (2021).
- [57] T. Rangnau, R. v. Buijtenen, F. Fransen, F. Turkmen, Continuous security testing: A case study on integrating dynamic security testing tools in ci/cd pipelines, in: 2020 IEEE 24th International Enterprise Distributed Object Computing Conference (EDOC), IEEE, 2020, pp. 145–154.
- [58] OpenAI, J. A. et al., Gpt-4 technical report (2024). *arXiv: 2303.08774*.
- [59] G. Team, Gemini: A family of highly capable multimodal models (2023). *arXiv:2312.11805*.
- [60] Infosys, Amazone codewhisperer: Early adoption of emerging technologies, <https://www.infosys.com/services/incubating-emerging-technologies/documents/early-adoption-infosys.pdf>, accessed: 2023-09-30 (2023).
- [61] O. B. Tauqeer, S. Jan, A. O. Khadidos, A. O. Khadidos, F. Q. Khan, S. Khattak, Analysis of security testing techniques, *Intelligent Automation & Soft Computing* 29 (1) (2021) 291–306.
- [62] H. H. AlBreiki, Q. H. Mahmoud, Evaluation of static analysis tools for software security, in: 2014 10th International Conference on Innovations in Information Technology (IIT), IEEE, 2014, pp. 93–98.
- [63] Microsoft, Security development lifecycle, accessed: 2023-09-24 (2021). URL <https://www.microsoft.com/en-us/securityengineering/sdl/>
- [64] A. Nguyen-Duc, M. V. Do, Q. L. Hong, K. N. Khac, A. N. Quang, On the adoption of static analysis for software security assessment—a case study of an open-source e-government project, *computers & security* 111 (2021) 102470.
- [65] G. Sandoval, H. Pearce, T. Nys, R. Karri, S. Garg, B. Dolan-Gavitt, Lost at c: A user study on the security implications of large language model code assistants (2023). *arXiv:2208.09727*.
- [66] MITRE Corporation, CWE-699: Software Development Weaknesses, <https://cwe.mitre.org/data/definitions/699.html>, accessed: 2024-03-02 (2023).
- [67] Snyk, Integrate with Snyk: IDE Tools, <https://docs.snyk.io/integrate-with-snyk/ide-tools>, accessed: 2024-03-12 (2024).
- [68] Amazon Web Services, AWS CodeWhisperer User Guide for Security Scanning, Amazon Web Services, accessed: 2024-03-29 (2023). URL <https://docs.aws.amazon.com/pdfs/codewhisperer/latest/userguide/user-guide.pdf#security-scans>
- [69] SixHq, Ai realtime code scanner sixth sast, <https://github.com/SixHq/>, accessed: 2024-05-04 (2023).
- [70] E. V. d. P. Sobrinho, A. De Lucia, M. d. A. Maia, A systematic literature review on bad smells—5 w’s: Which, when, what, who, where, *IEEE Trans. Softw. Eng.* 47 (1) (2021) 17–66. doi:10.1109/TSE.2018.2880977.
- [71] M. Esposito, S. Moreschini, V. Lenarduzzi, D. Hästbacka, D. Falessi, Can we trust the default vulnerabilities severity?, in: 2023 IEEE 23rd International Working Conference on Source Code Analysis and Manipulation (SCAM), 2023, pp. 265–270. doi:10.1109/SCAM59687.2023.00037.
- [72] A. Mohsin, H. Janicke, S. Nepal, D. Holmes, Digital twins and the future of their use enabling shift left and shift right cybersecurity operations, in: 2023 5th IEEE International Conference on Trust, Privacy and Security in Intelligent Systems and Applications (TPS-ISA), 2023, pp. 277–286. doi:10.1109/TPS-ISA58951.2023.00042.
- [73] I. H. Sarker, H. Janicke, A. Mohsin, A. Gill, L. Maglaras, Explainable ai for cybersecurity automation, intelligence and trustworthiness in digital twin: Methods, taxonomy, challenges and prospects, *ICT Express* (2024). doi:https://doi.org/10.1016/j.icte.2024.05.007.
- [74] R. Croft, Y. Xie, M. Zahedi, M. A. Babar, An empirical study of developers’ discussions about security challenges of different programming languages, *Empirical Software Engineering* (2022). URL <https://link.springer.com/article/10.1007/s10664-021-10054-w>
- [75] X. Xia, Z. Wan, P. S. Kochhar, D. Lo, How practitioners perceive coding proficiency, *IEEE/ACM 41st International Conference on Software Engineering* (2019).